



SEF[®] Lean Version

Architectural Principles

DISCLAIMER

This document is provided 'AS-IS' and its contents may change over time and without notice. Any examples used are for illustration only and are fictitious. No real association is intended or should be inferred. This publication does not constitute an endorsement of any product described.

Technognomi Ltd expressly disclaims any liability, which may arise in any manner and to any party through the publication of this document and application of the method contained. Any party acting for or failing to act as a result of this document assumes full responsibility for any use made of the information contained herein.

The direct or indirect reference to organisations, products, methods, frameworks, or standards does not imply that they are endorsed or recommended by Technognomi Ltd in preference to others of a similar nature that are not mentioned.

COPYRIGHT

This document is the property of Technognomi Ltd; the contents herein are the intellectual property and copyright of Technognomi Ltd. Disclosure of this document and its contents does not grant or construe and transfer or other rights in relation to Technognomi Ltd intellectual property.

© Copyright 2014+. Technognomi Ltd. All rights reserved.

TRADEMARKS

The SEF® Lean Version, as amended from time to time, is part of the Secure Enterprise Framework®, which is also known as SEF®. The Secure Enterprise Framework® and SEF® were trademarked by the European Union Intellectual Property Office (EUIPO) under Registration Number 017094137. All trademarks or registered trademarks either mentioned or implied are respected.

LICENCE



Except where otherwise indicated, this work is licensed by Technognomi Ltd under the Creative Commons (CC) BY-NC-ND 4.0 licence.

To view a copy of this license, please visit:

<https://creativecommons.org/licenses/by-nc-nd/4.0/>

Anyone wishing to adapt, modify, share, or distribute copies of the SEF® Lean Version for revenue generating purposes or wishing to utilise the method in any other way, must first obtain an appropriate licence from Technognomi Ltd by contacting the company at services@technognomi.com.

All trademark, copyright, or other notices affixed onto the SEF® Lean Version must be reproduced and may not be removed.

READERSHIP

This document is intended for enterprise architects, service architects, business architects, information architects, infrastructure architects, integration architects, security architects, and engineers who seek a common foundation of architectural principles, from which policies and standards can later be developed to shape architectural models.

SUGGESTED CITATION

BARUTTIS, A. (2020). *SEF® Lean Version - Architectural Principles* [PDF]. Release 4.0. Technognomi Ltd.

TABLE OF CONTENTS

AIM.....	5
PURPOSE	5
INTRODUCTION	5
1 EVOLUTION AND LIMITATIONS OF ARCHITECTURAL PRINCIPLES	6
1.1 STRUCTURAL DEFICIT IN ARCHITECTURAL PRINCIPLES	6
1.2 HISTORICAL CONTEXT OF ARCHITECTURAL PRINCIPLE APPLICABILITY	7
2 ARCHITECTURAL PRINCIPLES	9
2.1 METAMODEL.....	9
2.2 FORMAT	10
2.3 DETAILED LIST	11
2.3.1 Architectural Model	11
2.3.2 Structural Profile – Offering Domain	17
2.3.3 Structural Profile – Business Domain	22
2.3.4 Structural Profile – Knowledge Domain	29
2.3.5 Structural Profile – Application Domain.....	43
2.3.6 Structural Profile – Infrastructure Domain.....	50
2.3.7 Structural Profile – Facility Domain	60
2.3.8 Interface Profile	64
2.3.9 Security Profile	73
3 BENEFITS	81
GLOSSARY.....	83
REFERENCES.....	84

AIM

The aim of this document is to articulate, in detail, the architectural principles that support the SEF® Lean Version¹.

PURPOSE

The purpose of this document is to establish these architectural principles as the foundational constraints for developing architectural policies and, in turn, standards, thereby supporting decision-making that keeps the architectural landscape aligned with the strategic goals of the organisation.

INTRODUCTION

This document consists of three parts. The first part briefly traces the evolution and limitations of architectural principles over the last forty years, with a focus on the structural deficiency that persists and affects organisations. The second part presents the architectural principles by describing their metamodel and format before setting them out in detail, organised into groups mapped to the architectural model of the SEF® Lean Version. The third part outlines the business benefits of adopting and applying the architectural principles.

¹ The SEF® Lean Version is part of the Secure Enterprise Framework® (SEF®).

1 EVOLUTION AND LIMITATIONS OF ARCHITECTURAL PRINCIPLES

The use of architectural principles within contemporary enterprise environments remains fundamentally paradoxical. They are widely adopted as foundational steering mechanisms intended to align the architectural landscape with the strategic organisational direction, yet, in practice, their real-world application frequently degrades into passive documentation rather than active governance.

This systemic failure is not merely an execution deficit, but rather a deeper consequence of how principles are defined and enforced. By treating high-level, abstract guidelines as self-executing mandates, traditional management practices decouple architectural intent from engineering reality.

To understand why decades of industry effort have failed to translate these conceptual statements into tangible value, it is necessary to examine two things: the structural deficits built into how principles are typically formatted, and the historical context that shaped that format in the first place.

1.1 STRUCTURAL DEFICIT IN ARCHITECTURAL PRINCIPLES

It appears that, over the last two decades, organisations have increasingly published documents titled Architecture Principles. These documents are frequently referenced but rarely enforce actual governance. The fundamental issue is not a lack of principles, but confusion between the aim of a principle and its structural content. In addition, a principle without a policy is merely an opinion, and a policy without a standard is inapplicable. When these layers are disconnected, governance becomes theatrical. The resulting document is often a list of aspirations, stripped of the governance chain required to give it force, leaving the enforcement and application layers empty.

This structural deficit produces two distinct failure modes. Some organisations operate in conscious dysfunction, acknowledging that their principles are decorative but publishing them to satisfy audits or board requests. Documents are invoked reactively, to justify decisions after the fact, rather than proactively, to shape them. Other organisations operate in unconscious dysfunction, believing their principles are strategically aligned simply because they use contemporary terms (e.g., agility or resilience). However, no mechanism exists in either case to verify whether these principles actually contribute to a strategically aligned architectural landscape. In both scenarios, organisations fail to recognise principles as constraints for shaping architectural models.

Both failure modes manifest in three specific ways. First, organisations publish policies or slogans as if they were principles. Second, principles are copied directly from the examples given in generic frameworks. Third, principles cannot be traced to any specific industry good practice or organisational goal, which leaves them decorative rather than structural. None of these problems can be solved by writing better prose. They require discipline about what a principle actually is and what it must be capable of supporting.

1.2 HISTORICAL CONTEXT OF ARCHITECTURAL PRINCIPLE APPLICABILITY

The concept of an architectural principle dates back a few decades. Rivera (2013) traces its introduction to the Partnership for Research in Information Systems Management (PRISM), a framework developed in 1986, although Kotusev (2016) locates an earlier, more rudimentary version of the idea in the work of King (1978). The PRISM formulation was subsequently carried forward by Richardson et al. (1990), later adopted by The Open Group, which went on to shape the treatment of principles in TOGAF®.

Rivera (2013) describes the original PRISM conception of a principle as a statement of the information systems philosophy of an organisation, expressed as objectives and goals across domains such as infrastructure, application, data and organisation. This concept was later refined by the authors of PRISM into a narrower definition, describing principles as concise statements of the core beliefs held by an organisation regarding its intended use of information technology over an extended period. This emphasis on durability remains central to the intended purpose of a principle, serving as guidance designed to outlast the individual decisions made under it. This contrasts with requirements, which are far more transient and are better understood as choices regarding the implementation of a principle in a specific instance. From this perspective, principles precede requirements and can be utilised as a basis for testing the validity of a requirement (Rivera, 2007).

This orientation towards reasoning that endures and is guided by principles, rather than design driven by requirements, is one of the features Rivera (2007) uses to distinguish architecture work from engineering or detailed design work. Furthermore, the practice of grounding architectural descriptions in principles has persisted as a professional norm ever since.

The credibility of this approach was established early. Dietrich (1995) emphasised the critical need for integrating business and information technology. Rivera (2013) later confirmed that the PRISM framework, and its principles-based approach to architecture, was already regarded as a leading model for this very purpose by the mid-1990s. TOGAF® later codified the idea in similar terms, defining principles as general rules and guidelines intended to be enduring and rarely amended, and which inform and support the manner in which an organisation pursues its mission.

It is notable that this definition has undergone minimal change over the intervening decades. Comparing formulations across sources suggests greater continuity than evolution. For instance, the treatment of data as a corporate asset to be actively managed by Richardson et al. (1990) is echoed almost exactly in the data principle of TOGAF®. The intent behind that principle is reasonable, yet it omits the fact that data possesses no operational value until it is contextualised as information and further refined into knowledge, which is the stage at which it may genuinely function as an asset.

Given that the underlying concept has remained this static for over thirty years, it raises a pertinent question regarding whether the prevailing definition of a principle, alongside the manner in which organisations apply it, is genuinely capable of shaping architectural models that represent coherent and strategically aligned states of the landscape of an organisation.

Despite decades of utilisation and sustained attention from both academia and industry, it remains an open question whether architectural principles, as currently defined and practised, deliver substantial tangible value to the organisations that adopt them.

The architectural principles presented in the SEF® Lean Version provide the foundation for delivering the missing tangible value. They are intended to serve as the basis to which enforceable policies and supporting standards can be linked to transform architectural intent into architectural action.

The relationship between the three constraints is hierarchical and cascades from one to many. A principle can be enforced by policies, and a policy can be supported by standards. A consequence of this hierarchy is that a flaw at the level of the principle propagates through everything built beneath it. A weak principle produces weak policies and weak standards, regardless of how carefully those lower layers are drafted.

2.2 FORMAT

All principles follow the format introduced by the PRISM framework and later adopted by The Open Group. Each principle has an **item**, which is a unique **identifier**, a **name**, which is a distinct **label**, a **statement**, which is the **description**, a **rationale**, which is the **justification**, and **implications**, which are the **consequences**.

The coverage of these principles, depicted in fig. 2, starts at the model level, where principles ensure coherence between profiles, domains, and building blocks. From there, principles extend across every domain of the structural profile, as well as the interface and security profiles.

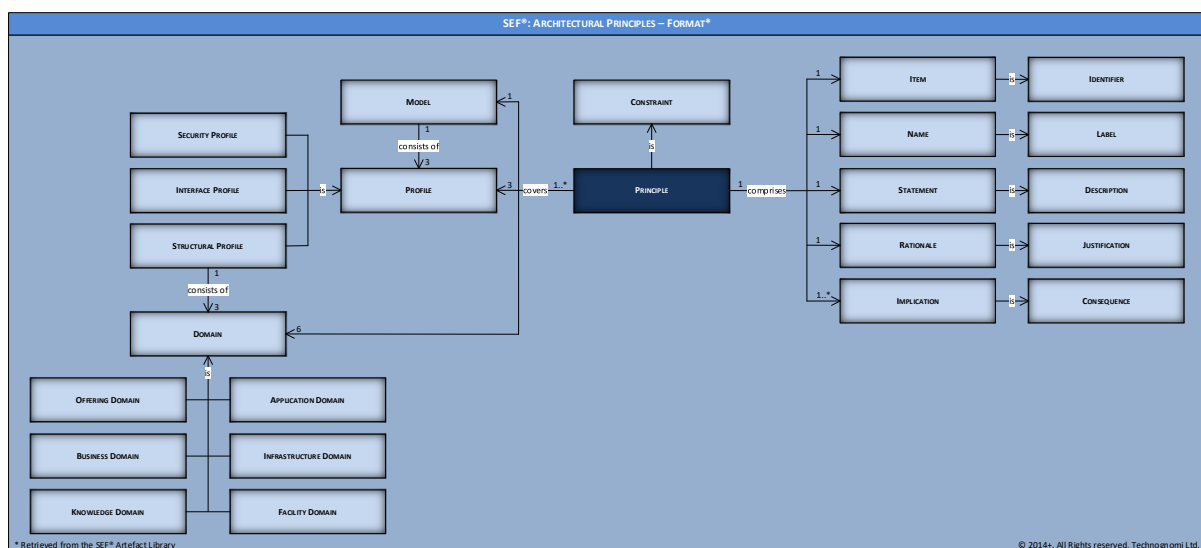


Figure 2. SEF® Lean Version: Architectural Principles – Format

2.3 DETAILED LIST

The list of architectural principles is grouped by the architectural model, the domains of the structural profile, including offering, business, knowledge, application, infrastructure, and facility, and the interface and security profiles.

Across all of these groups, the complete set of principles is required to remain internally consistent, such that satisfying one principle does not require violating another. A set of principles that contradict each other gives architects and engineers no reliable basis for decisions, since any choice can be justified by one principle and condemned by another. Coherence across the groups ensures the principles function as a single, usable structure rather than a loose collection of statements grouped for convenience. Reviewing a new principle against the existing set may slow its addition, but allows conflicts to surface during governance review rather than later during design, and may in turn require some existing principles to be revised or retired as tensions between groups are discovered.

2.3.1 ARCHITECTURAL MODEL

The architectural model includes seventeen architectural principles, which are presented in table 1.

Item	Name	Statement	Rationale	Implications
PRL 001	Profile completeness	Each profile, structural, interface, and security, describes its subject matter holistically, with no gaps or overlaps between what any two profiles claim to cover.	A profile that leaves part of its subject undescribed forces that gap to be resolved informally, outside the model, while two profiles that overlap create ambiguity about which one governs a given decision. Requiring each profile to be complete and mutually exclusive ensures every aspect of the architecture is described exactly once, by exactly one profile.	– Boundaries between profiles may need to be explicitly tested and agreed, rather than assumed to be self-evident. – Content that appears to belong to more than one profile may need to be resolved by assigning it to a single profile of record, with the others referencing it rather than duplicating it. – Gaps may only become visible once a real requirement fails to fit cleanly within any profile, requiring the model to be extended.

Item	Name	Statement	Rationale	Implications
PRL 002	Domain hierarchy	The domains of the structural profile are arranged hierarchically, from offering at the top to facility at the bottom, with requirements flowing downward from one domain to the next.	Without a defined hierarchy, requirements can originate at any domain independently, with no basis for resolving conflicts between domains or for tracing a requirement back to the business need it serves. Ordering the domains hierarchically ensures every requirement can be traced to its origin, and that domains lower in the hierarchy are shaped by the domains above them rather than the reverse.	– Domains lower in the hierarchy may need to wait for requirements from domains above them to be defined before their own requirements can be finalised. – Reordering or challenging the hierarchy may have wide-reaching consequences, since every domain below depends on the ordering remaining stable. – Domains distant from offering (e.g., facility), may only receive requirements after several intermediate domains have already interpreted and passed them on.
PRL 003	Requirement alignment	Requirements targeting a domain in the middle of the hierarchy (e.g., application, infrastructure) are aligned with the requirements of the domains above it, rather than originating independently.	A requirement defined at a middle domain without reference to the domains above it is not derived from genuine business need. It is invented at that domain and then pushed upward to retrofit a justification, creating a silo that serves the domain rather than the business it should support. Requiring alignment ensures every requirement can be traced upward through the hierarchy to the business need it ultimately serves.	– Middle domains may need to defer or revise requirements that cannot be traced to the domains above them. – Evaluation criteria may be needed to confirm that the requirements of a domain are actually derived from the requirements above it, since a requirement that merely avoids contradicting those above it may still have originated independently at that domain, rather than being caused by a genuine need from above. – Domains that repeatedly generate unaligned requirements may indicate a genuine gap in the domains above them that has not yet been addressed. – Requirements that cannot be traced upward may indicate a silo has already formed at that domain, where the domain is generating its own justification for a requirement rather than deriving it from genuine business need.
PRL 004	Conceptual description	The model is described conceptually through building blocks, each representing a concept with a defined boundary that delivers a finite function.	Without a conceptual layer expressed as discrete building blocks in the conceptual architecture, the architectural model has no stable, agreed inventory of what exists, independent of how those things behave together or how they are implemented. Building blocks provide this stable, implementation-independent description of what the model consists of.	– New concepts introduced into the model may need to be expressed as building blocks before they can be described behaviourally or implemented. – Building blocks that do not deliver a finite, identifiable function may need to be decomposed further or merged with an adjacent block. – Changes to the conceptual architecture may ripple into the behavioural and implementation architectures that depend on it.

Item	Name	Statement	Rationale	Implications
PRL 005	Behavioural description	The model is described behaviourally through architectural patterns, formed by combining building blocks with the interfaces that connect them.	Building blocks alone describe what exists but not how it behaves. Without architectural patterns, there is no description of how building blocks interoperate to deliver the behaviour the architectural model is meant to produce. The architectural patterns of the behavioural architecture provide this reusable, consistent description of interaction, independent of how that interaction is ultimately implemented.	– Architectural patterns may need to be reviewed whenever the building blocks or interfaces they are composed of change. – The same pattern may be reused across multiple parts of the model, reducing the need to design interaction from scratch each time. – Behaviour that cannot be expressed as a pattern of existing building blocks may indicate a missing building block in the conceptual architecture.
PRL 006	Implementation description	The model is described in implementation through selected solutions that realise the architectural patterns of the behavioural architecture.	Architectural patterns describe how building blocks should interoperate, but only solutions make that interoperation real, whether through technology or another non-technical means (e.g., service, process, dataset, etc.). The implementation architecture defines the solutions with which the patterns of the behavioural architecture are realised, and these solutions are described further through corresponding high-level and low-level designs.	– Solutions proposed without a corresponding pattern may need to be rejected or deferred until the pattern they would realise has been defined. – The same pattern may be realised by different solutions in different contexts, whether technical or non-technical, provided each solution satisfies the pattern it implements. – Replacing a solution does not require the underlying pattern to change, provided the replacement continues to realise the same pattern.
PRL 007	Configuration and integration	Gaps between building blocks, where their boundaries do not directly align, are closed through configuration and integration effort.	Building blocks are defined independently and will not always align perfectly at their boundaries when combined into patterns or realised as solutions. Configuration and integration effort is the mechanism by which these gaps are closed, rather than being absorbed silently into the building blocks themselves, which would compromise their atomicity.	– Integration effort may need to be estimated and planned for separately from the design of the building blocks themselves. – Frequent or extensive configuration and integration effort between two building blocks may indicate that their boundaries were not well defined. – Solutions may need to include integration components (e.g., adapters or connectors) that exist solely to close gaps between building blocks.
PRL 008	Low coupling	Profiles, domains, and building blocks exhibit low coupling between one another.	Tightly coupled profiles, domains, or building blocks cannot be changed, replaced, or scaled independently. Requiring low coupling at every level ensures the model remains modifiable as it grows.	– Achieving low coupling may require additional design effort to define stable interfaces between profiles, domains, and building blocks. – Reducing coupling between two elements may increase the number of interfaces needed to connect them. – Coupling may need to be periodically reassessed, since it can degrade gradually as the model evolves.

Item	Name	Statement	Rationale	Implications
PRL 009	High cohesion	Profiles, domains, and building blocks exhibit high cohesion within themselves.	Low internal cohesion scatters related functionality across multiple elements, making the model harder to understand and maintain. Requiring high cohesion at every level ensures the model remains comprehensible as it grows.	– Elements exhibiting low cohesion may need to be split into smaller, more focused elements. – Achieving high cohesion may require functionality currently scattered across several elements to be consolidated into one. – Cohesion may need to be periodically reassessed, since it can degrade gradually as the model evolves.
PRL 010	Modularity	Building blocks are atomic and modular, each with a specific function and boundaries and responsibilities that do not overlap with any other building block.	A building block combining multiple functions, or whose boundary overlaps with that of another block, cannot be independently controlled, replaced, or reasoned about, and creates ambiguity about which block is accountable for a given outcome. Modularity ensures each building block can be managed on its own terms.	– Building blocks found to overlap with one another may need to be redefined or merged to remove the ambiguity. – Decomposing the model into atomic building blocks may increase the total number of blocks, and correspondingly the number of interfaces between them. – A function that does not fit clearly within a single building block may indicate a gap in how the model has been decomposed.
PRL 011	Traceability	Solutions are traced to the architectural patterns they realise, and architectural patterns are traced to the building blocks they are composed of, with all three kept aligned.	Without traceability across all three architectures, a solution can drift from the pattern it was meant to realise, or a pattern can drift from the building blocks it was meant to compose, without anyone being able to detect the divergence. Maintaining traceability ensures a change at any layer can be verified against the layers it depends on.	– Documentation or tooling may be needed to maintain visible traceability between building blocks, patterns, and solutions as the model evolves. – Misalignment between a solution and its pattern, or a pattern and its building blocks, may only be discovered through periodic review rather than immediately. – Changes at any one layer may require a traceability check against the layers above and below before being accepted.
PRL 012	Reusability	Building blocks, architectural patterns, and solutions are reused across the model where a genuine match exists, rather than recreated independently.	Recreating a building block, pattern, or solution that already exists elsewhere in the model duplicates effort and risks producing inconsistent variants of what should be the same underlying concept. Reuse, where a genuine match exists, keeps the model consistent and reduces unnecessary duplication.	– Identifying reuse opportunities may require the model to be searchable or well catalogued, so existing building blocks, patterns, and solutions can be found before new ones are created. – Reusing an existing element may require it to be generalised beyond the needs of its original context, which can increase its initial design complexity. – Reuse may not always be appropriate, and forcing it where a genuine match does not exist may create an inaccurate or overly complex model.

Item	Name	Statement	Rationale	Implications
PRL 013	Interoperability	Building blocks, and the patterns and solutions built from them, are capable of interacting with one another through defined interfaces, whether internal or external to the model.	Building blocks that cannot interact with one another cannot be combined into architectural patterns, and patterns that cannot interact cannot be combined into a coherent architectural model. Interoperability, established through defined interfaces, is the precondition for building blocks and patterns to function together as a single model rather than as isolated, disconnected parts.	– Interfaces between building blocks may need to be defined and agreed before the building blocks themselves are considered complete. – Building blocks that cannot interoperate with any other block may indicate they do not belong within the model as currently scoped. – Interoperability may need to extend beyond the model itself, where a building block interacts with entities external to the organisation.
PRL 014	State representation	The model represents the current, target, and interim states of the architecture, distinguishing what exists today from what is intended and from what exists during the transition between the two.	An architectural model that describes only a single state cannot support planning, since it provides no basis for comparing where the architecture is now against where it is intended to go, or for describing the sequence of states it must pass through to get there. Representing current, target, and interim states allows the model to support both assessment and transition planning.	– Building blocks, architectural patterns, and solutions may need to be tagged or versioned according to the state they belong to, rather than assumed to represent a single, permanent condition. – Interim states may need to be defined even where they are transient, since they represent real conditions the architecture will pass through. – Comparing current and target states may reveal gaps that were not visible when only one state was considered at a time.
PRL 015	Viewpoint scoping	Every viewpoint unambiguously defines the domains, profiles, and level of abstraction it covers, together with the format and language in which its corresponding views are to be presented.	A viewpoint that does not clearly record its own scope cannot be relied upon to produce consistent views over time, or to be distinguished from other viewpoints covering a similar or overlapping part of the model. Recording the domain, profile, and abstraction filters explicitly, alongside the intended format and language, preserves the agreement stakeholders have reached on what a view will and will not cover, allowing that agreement to be verified before a view is produced, rather than discovering gaps or overlaps afterwards.	– Stakeholders may need to agree explicitly on the domains, profiles, and abstraction level a viewpoint covers before any view based on it is produced. – Abstraction levels may need to be standardised across the whole model, so that a given level means the same thing regardless of which domain or profile a viewpoint covers. – Viewpoints intended for non-technical stakeholders may need to define a restricted language, with technical terms avoided or linked to a centralised lexicon where unavoidable.

Item	Name	Statement	Rationale	Implications
PRL 016	Concern-driven views	Every view addresses the concerns of a defined group of stakeholders through an associated viewpoint, containing neither more nor less information than those concerns require, and independent of the architectures and designs it may or may not be derived from.	Stakeholders differ in what they need to know about the model, and a view built around the underlying architectures and designs rather than around a specific concern may be unusable by a stakeholder who has no interest in that structure. Producing a view from a defined viewpoint, decoupled from the architectures and designs where necessary, ensures the information it presents is proportionate to the concern it exists to address, since providing more or less information than required leads to time being spent resolving misunderstandings that could otherwise have been avoided.	– A view intended for a specific stakeholder group (e.g., compliance managers), may need to be produced independently of the conceptual, behavioural, and implementation architectures, where those stakeholders have no interest in them. – Views containing unavoidable technical terms may need to reference a centralised lexicon, rather than relying on fragmented, view-specific glossaries that risk falling out of alignment with one another. – Every view may need to be traceable to the specific stakeholder concern and viewpoint it was produced to address, so that its scope and sufficiency can be verified against that concern.
PRL 017	Minimum necessary complexity	The model and the building blocks, patterns, and solutions that describe it, introduce no more complexity than is required to meet the defined need.	Unnecessary complexity increases the cost of understanding, maintaining, and changing the model, whichever of the three it belongs to, without adding corresponding value. Keeping complexity to the minimum required preserves the model long-term manageability across all three architectures.	– Design reviews might need an explicit complexity check at each architecture and design, rather than assessing building blocks, patterns, and solutions on functionality alone. – Delivery timelines could shorten where simpler solutions are accepted over more elaborate ones. – Future extensibility may be constrained if a simpler building block, pattern, or solution proves harder to extend than a more complex alternative would have been.

Table 1. SEF[®] Lean Version: Architectural Principles – Architectural Model

2.3.2 STRUCTURAL PROFILE – OFFERING DOMAIN

The offering domain of the structural profile includes fifteen architectural principles, which are presented in table 2.

Item	Name	Statement	Rationale	Implications
PRO 001	Business product ownership	Each business product has a clearly defined owner accountable for its market strategy, customer value proposition, and alignment with organisational objectives, across all components the product comprises.	Clear ownership of business products promotes accountability for the overall customer proposition, even where a product is delivered through multiple underlying business services. With a designated owner, each product has a single point of accountability for strategic direction, feature decisions, and commercial or public value outcomes, reducing ambiguity between product-level strategy and service-level delivery.	– Product owners might be required to coordinate with the owners of the business services their products depend on, without assuming accountability for the operational delivery of those services. – Reporting mechanisms may be needed to track product-level outcomes, such as market position or revenue, separately from the operational metrics owned by service owners. – Organisational structures might need to be established to distinguish product ownership from service ownership, including clarity on decision rights where a product spans several services.
PRO 002	Business service ownership	Each business service has a clearly defined owner accountable for its lifecycle, performance, quality, and alignment with organisational objectives.	Clear ownership of business services promotes accountability, enhances service quality, and ensures continuous alignment with business objectives. With a designated owner, each service has a point of contact for decision-making, issue resolution, and improvement, reducing ambiguity and improving responsiveness to evolving business needs.	– Service owners may be required to monitor and report on service performance, aligning it with evolving business needs. – Training and support may be necessary to equip service owners with the skills and tools needed to manage services effectively. – Organisational structures might need to be established to support and recognise service ownership, including decision rights and accountability mechanisms.
PRO 003	Business service valuation	Every business service, whether internally provided or consumed from a third party, is assigned a criticality level that reflects the adverse operational and financial impact its failure, degradation, or compromise would have on the organisation.	Business services deliver value to customers and generate revenue. Their failure, degradation, or compromise directly impacts customer experience, revenue, and regulatory compliance. Without a clear criticality valuation of their integrity and availability, decisions about investment, resilience, and recovery become subjective and inconsistent. A business service supporting a core revenue stream requires higher availability and integrity than one used for internal administrative purposes. Valuation ensures proportionate investment in reliability, security, and recovery, and directly informs Business Continuity Plans (BCPs).	– Business services that support multiple products or customer segments might require aggregated criticality scoring that reflects the highest-impact outcome they enable. – Revaluation of business service criticality might be required whenever the underlying business processes or information assets are reclassified or retired. – Criticality levels of business services might need to directly inform Business Continuity Plans (BCPs). – Business services consumed from third-party providers, such as Content Delivery Network (CDN) and Domain Name System (DNS), might need to be assessed for criticality, with the organisation recognising that accountability remains with the

Item	Name	Statement	Rationale	Implications
				organisation even if the services are externally produced and operated.
PRO 004	Aligned business services	Business services are aligned with business products to ensure that they effectively support and enhance business outcomes.	Aligning business services with business products ensures that services directly contribute to the market strategy and customer value proposition the product is designed to deliver. This alignment assists to streamline operations, optimises resource utilisation, and improves decision-making by ensuring that the right services are available to support the corresponding products. It also fosters efficiency by identifying and preventing redundant or misaligned services that may detract from core product priorities.	– Product models may need to be developed to map essential product components and ensure that business services are designed to support them. – The design of business services may require close collaboration between product owners and business service designers to ensure that services align with evolving product needs and objectives. – Continuous review and adaptation of business services may be necessary to maintain alignment with the changing composition and strategic priorities of products.
PRO 005	Customer Centric	Business services are designed and delivered around the needs and experience of the customer, so that interactions are intuitive, efficient, and valuable.	A business service designed around internal convenience rather than the customer results in friction, disengagement, and lost trust. Placing the customer at the centre of design keeps the service aligned with what customers actually value, rather than what is easiest for the organisation to deliver.	– Customer needs and reactions might need to be assessed directly, rather than inferred from internal assumptions about what customers want. – Business services may require design input from user experience disciplines, so that the interaction itself, not only the underlying function, is fit for purpose. – Existing services may need to be revisited where their design reflects internal convenience rather than customer need.
PRO 006	Consistent delivery	Business services are consistently delivered to meet defined customer expectations.	Consistency in service delivery reduces errors and inefficiencies, and builds reliability and trust with internal and external customers, ensuring that they receive the same level of service every time they consume it.	– Standardised business processes may be needed to ensure uniformity in service delivery. – Performance monitoring may be required to monitor and evaluate service performance regularly, thus ensuring adherence to expected outcomes and identifying areas for improvement. – Feedback business processes and software systems may be needed to gather and analyse customer feedback, using it to make informed adjustments to service delivery practices.

Item	Name	Statement	Rationale	Implications
PRO 007	Atomic business services	Each business service performs a single, well-defined function that can be independently deployed, managed, and reused.	Atomic business services increase modularity, flexibility, and reusability, which simplify service maintenance, enhance scalability, and enable quicker response to changing business requirements. They also reduce interdependencies, allowing for individual updates or replacements without affecting other services, thus promoting a resilient and adaptable architecture.	– Business services may be subject to enhanced modularity, allowing individual services to be developed, tested, and deployed independently. – Business services may require clear definition and documentation of their scope and boundaries to ensure they perform distinct, singular functions. – Service deployment and integration mechanisms may need to support independent deployment and interoperability, enabling atomic services to be seamlessly combined or scaled as needed.
PRO 008	Independent business services	Business services are decoupled from specific business processes and technologies.	Independent business services are flexible, reusable, resilient, and easier to maintain. They can be modified without affecting other services, they reduce the risk of system-wide failures, enable more flexible evolution of the service landscape, and are adaptable to different contexts without dependencies on specific processes or technologies.	– Business services may be required to be technology agnostic to be used across various platforms and environments. – Business services may be required to be modified or replaced without impacting other business processes or software systems. – Service isolation mechanisms may be needed to ensure autonomy. – Interface contracts may be required to manage service boundaries. – Monitoring software systems may be needed to track service dependencies.
PRO 009	Adaptable business services	Business services are adaptable, enabling them to respond quickly to changing environmental conditions, business requirements, technological advancements, and market conditions.	Adaptable business services support organisational agility, resilience, and competitiveness by allowing for rapid adjustments to business processes and technology without extensive rework. They also assist to future-proof the organisation, ensuring that services remain relevant and effective as needs evolve, and fostering a more innovative, responsive business environment.	– Business services may be designed with flexibility in mind, allowing for easy modifications and extensions without significant rework. – Business services may need to be scalable to support growth and change without compromising performance. – Modular designs and flexible integration points may be necessary to enable business services to adjust to new business processes, technologies, or regulatory changes. – Continuous monitoring and feedback mechanisms may be needed to assess service performance and identify areas for enhancement to keep up with changing demands. – Resources for rapid development, testing, and deployment may be required to enable quick adjustments and updates to services, supporting a culture of continuous improvement.

Item	Name	Statement	Rationale	Implications
PRO 010	Measurable business services	Business services are measurable, with clearly defined metrics to assess their performance, efficiency, and effectiveness.	Measurable business services support objective evaluation, enabling decisions to be made on the basis of data, and continuous improvement. Measurable performance metrics allow the organisation to monitor, evaluate, and optimise service effectiveness. In addition, measurability fosters accountability and transparency.	– Key Performance Indicators (KPIs) may need to be defined for each business service, covering metrics such as response time, availability, user satisfaction, and cost-effectiveness. – Monitoring and reporting software systems might be required to collect, analyse, and report on business service performance data, supporting regular review and improvement cycles. – Resources for analytics and performance assessment may be necessary to ensure that business service data are accurately tracked, and actionable insights are generated for continuous service enhancement.
PRO 011	Multi-channel access	Business services are accessible through multiple channels to ensure ease of use and convenience for all consumers.	Multi-channel access enhances user experience, convenience, accessibility, and engagement by reaching customers where they are and adapting to their preferred platforms. This access improves customer satisfaction, ensures inclusivity, and expands the reach of services, assisting the organisation to cater to a diverse customer base and maximise service utility.	– Software systems that integrate and synchronise information across channels may be needed to allow customers to switch between them seamlessly without loss of context or data. – Business services may need to be designed using responsive or adaptive interfaces, ensuring consistent functionality and appearance across various devices and channels. – Security controls may need to be implemented across all channels to protect data and ensure compliance, regardless of the access point.
PRO 012	Multi-platform access	Business services are accessible across multiple platforms, enabling customers to interact with services seamlessly from a variety of devices.	Ensuring business services are available across multiple platforms increases customer flexibility, satisfaction, and reach. With the growing diversity of devices, operating systems, and customer preferences, offering multi-platform access enables the organisation to cater to a broader audience, enhancing service adoption and customer engagement.	– Business services may need to be created using responsive or adaptive design techniques to ensure consistent usability and appearance across different devices and screen sizes. – Integration solutions may be required to ensure that business services function correctly across different operating systems and device types, such as laptops, desktops, smartphones, tablets, and Internet of Things (IoT) devices. – Continuous testing and customer feedback may be necessary to ensure that business services perform well across the diverse range of platforms customers use, identifying and addressing potential platform-specific issues.

Item	Name	Statement	Rationale	Implications
PRO 013	Business service continuity	Business services ensure continuity, minimising service disruptions and ensuring availability during planned and unplanned events.	Continuity is critical for maintaining business operations, safeguarding customer trust, and reducing the impact of service disruptions. By implementing robust continuity plans, including business service continuity in disaster recovery and Business Continuity Plans (BCPs), organisations can ensure that business services remain available and functional even in the face of unforeseen circumstances, such as system failures, natural disasters, or cyberattacks.	– Redundant, backup, and failover mechanisms may be required to ensure that business services remain operational during disruptions. – Regular testing and updating of continuity and disaster recovery plans may be necessary to verify their effectiveness and address emerging risks. – Business services may need to be designed with scalability in mind to handle high availability requirements and accommodate increased demand during periods of disruption.
PRO 014	Inclusive business services	Business services are inclusive, ensuring accessibility and usability for all customers, regardless of their abilities, backgrounds, or technological access.	Inclusivity in business services promotes equal access, fostering an environment where all customers can engage with services effectively and without barriers. It also expands the reach of services to a broader customer base, improving customer satisfaction, organisational reputation, and compliance with legal and regulatory requirements.	– Accessibility guidelines (e.g., Web Content Accessibility Guidelines) may need to be integrated into the design and testing processes to ensure services meet the needs of customers with disabilities. – Diverse customer input may be needed during the design phase to incorporate different perspectives and address potential barriers for various customer groups. – Training and guidelines on inclusive design may be necessary to create business services that are intuitive and usable by a wide range of customers, enhancing the inclusivity of service offerings. – Feedback mechanisms may be needed to gather feedback from a diverse customer base to continuously improve inclusivity.
PRO 015	Accessible business services	Business services are accessible regardless of geographical location, climate conditions, or variations in infrastructure, ensuring reliable service availability for all customers.	Ensuring accessibility across locations and conditions promotes a consistent customer experience, reliability, and broader reach of business services. By addressing regional connectivity, environmental, and infrastructure challenges, the organisation can maintain service availability and quality for customers globally, enhancing customer satisfaction, resilience, and organisational reputation.	– Redundant and resilient infrastructure may be necessary to maintain service continuity in regions with unreliable connectivity or power supplies. – Business services may need to be optimised for low-bandwidth environments to ensure usability for customers with limited or variable internet access. – Deployment approaches might include local datacentres or Content Delivery Networks (CDNs) to reduce latency and improve service speed for geographically dispersed customers.

Table 2. SEF® Lean Version: Architectural Principles – Structural Profile – Offering Domain

2.3.3 STRUCTURAL PROFILE – BUSINESS DOMAIN

The business domain of the structural profile includes twenty architectural principles, which are presented in table 3.

Item	Name	Statement	Rationale	Implications
PRB 001	Business process ownership	Each business process has a clearly defined owner accountable for its lifecycle, performance, quality, and alignment with the corresponding business service.	Assigning ownership to each business process ensures accountability, enabling consistent oversight of the efficiency, effectiveness, quality, and alignment of the process with the business service it supports. A designated owner facilitates ongoing improvements, promptly addresses issues, and ensures that processes evolve to meet changing business needs.	– Clearly defined ownership structures may be needed to establish and document accountabilities across all business processes. – Business process owners require sufficient authority and resources to drive improvement initiatives, which may necessitate changes to decision-making structures and budget allocation. – Business process ownership requires ongoing monitoring and periodic review mechanisms to ensure processes remain aligned with evolving business needs, demanding dedicated analytical resources.
PRB 002	Business function ownership	Each business function has a clearly defined owner accountable for developing the competencies of the business roles assigned to it, ensuring those competencies align with organisational core competencies.	Assigning ownership to each business function ensures that the people executing business processes are equipped, through job descriptions, development, training, and awareness, to perform their roles effectively. A designated owner ensures competency development remains connected to organisational core competencies, rather than being addressed inconsistently across individual business roles.	– Business function owners might be required to coordinate with business process owners to identify which competencies the roles executing their processes need to perform effectively. – Training and development programmes may need to be established or revised where existing role competencies do not yet align with organisational core competencies. – Job descriptions and role definitions may require periodic review to ensure they continue to reflect the competencies the function is accountable for developing.
PRB 003	Business process valuation	Every business process is assigned a criticality level that reflects the adverse operational and financial impact its failure, degradation, or compromise would have on the organisation.	Business processes deliver business services or business goods. Their failure, degradation, or compromise directly impacts revenue, operational continuity, regulatory compliance, and security. Without a clear criticality valuation of their integrity and availability, decisions about automation, resourcing, and improvement become subjective and inconsistent. A business process that delivers a core revenue-generating service requires higher integrity and availability than one used for internal administration. Valuation ensures proportionate	– Business processes might need to be assessed for criticality in terms of their integrity and availability, as their failure, degradation, or compromise directly impacts the business services or business goods they deliver. – Business processes that support multiple business services might require aggregated criticality scoring that reflects the highest-impact service they deliver. – Revaluation of business process criticality might be required whenever the business services or goods are reclassified or retired.

Item	Name	Statement	Rationale	Implications
			investment in process reliability, security, and resilience.	– Criticality levels of business processes might need to directly inform decisions about automation, manual intervention, and investment in process improvement.
PRB 004	Defined boundaries and transparency	Roles, boundaries, responsibilities, accountabilities, and performance expectations are clearly defined and published for every business role, whether accountable for its own actions, the actions of others, or both, to foster transparency.	Clear definition of roles, boundaries, responsibilities, and accountabilities within business functions and business processes ensures that individuals understand their specific areas of responsibility and accountability, reducing ambiguity and enhancing collaboration. By fostering transparency, trust and clarity are promoted, overlaps and conflicts in responsibilities and accountabilities are minimised, and more effective performance monitoring is achieved.	– Clear governance structures may be needed to define business roles, with unambiguous boundaries, responsibilities and accountabilities, and integrated management of risks. – Transparent decision-making and accountability mechanisms need to be in place to ensure that all actions and decisions are traceable and justifiable. – Additional documentation about roles may be required to establish clarity across business functions and business processes. – Regular and transparent reviews, aligned with published roles, may be needed to support fair performance assessments, identify improvement areas, and reinforce boundaries, responsibilities, and accountabilities. – Cross-functional coordination mechanisms may need to be implemented to manage dependencies and reduce operational friction.
PRB 005	Business process value centrality	Business processes are the primary drivers of value creation; they need to be designed, managed, and continually optimised to deliver measurable business outcomes while maintaining operational excellence.	Business processes form the foundation of how the organisation creates and delivers value to stakeholders, and they represent the structured way work gets done, turning inputs into valuable outputs. When properly designed and managed, business processes enable consistent delivery of business outcomes, facilitate performance measurement, and create opportunities for continuous improvement.	– The organisation might need to establish comprehensive business process governance and dedicated teams to manage, monitor, and improve processes. – Decision-making at all levels may become more business process-centric, where changes and improvements could require careful consideration of process impacts. – Business process owners might need to prioritise process performance metrics alongside traditional financial measures when evaluating business performance.

Item	Name	Statement	Rationale	Implications
PRB 006	Value delivery	Business processes deliver maximum value to customers and stakeholders.	Focusing on value delivery ensures that business activities are aligned with the outcomes of the business services that represent customer and stakeholder needs, driving satisfaction and business success.	– Clear metrics may be needed to monitor the value delivered by business processes against the corresponding outcome targets of the business services. – Customers may need to be engaged regularly to gather feedback and ensure that business processes are delivering the expected value. – Continuous improvement practices may be required to enhance the value delivered by business processes. – Innovation in business process modelling and execution may need to be encouraged to find new ways to deliver value.
PRB 007	Aligned business processes	Business processes are aligned with business services to ensure that they effectively support and enhance business outcomes.	Aligning business processes with business services enhances coherence and reduces redundancy. In addition, it enables a seamless connection between organisational resources, business processes, and desired outcomes. This alignment eliminates inefficiencies caused by processes operating in isolation or failing to support intended business outcomes. When processes are deliberately mapped to business services, the organisation can better allocate resources, measure performance, and create value through their operational activities.	– The organisation might experience significant changes in how business processes are managed, as business process owners may need to continuously evaluate and adjust their activities against service outcomes. – Business processes may require regular evaluation to confirm their alignment with service outcomes. – Traditional performance metrics and optimisation approaches might shift from focusing purely on business process efficiency to include measures of service effectiveness.
PRB 008	Value realisation and measurement	Business processes include mechanisms to measure and realise value, ensuring that each process contributes to the corresponding business service.	Embedding value measurement within business processes ensures that all their activities contribute meaningfully to the corresponding business services. By systematically tracking the value generated, the organisation can make informed decisions about resource allocation and business process improvement.	– Business processes may require value tracking metrics and reporting systems to monitor performance. – Periodic reviews may be conducted to assess whether each business process continues to deliver intended value. – Resources may be reallocated based on value measurement insights to prioritise high-impact business processes.
PRB 009	Functional process enablement	Each business function plays a critical role in delivering competencies and resources essential for the effective execution of business processes.	Business functions are the foundational structures within the organisation that provide necessary resources and competencies for other areas. By defining and reinforcing the essential roles of these functions, the organisation ensures that core competencies and specialised expertise are available to support business processes effectively.	– Clear functional architectural views may be needed to outline the specific contributions and objectives of each business function. – Resource allocation may prioritise functions that deliver high-impact services essential to organisational success. – Cross-functional collaboration mechanisms may be established to enhance the collective contributions of business functions to business services via corresponding business processes.

Item	Name	Statement	Rationale	Implications
PRB 010	Organisational collaboration	Business functions are integrated through business processes to ensure seamless collaboration.	Interoperation across business functions through well-defined business processes fosters a collaborative environment that enhances the ability of the organisation to respond effectively to complex challenges and customer needs. By ensuring that business functions work together cohesively, the organisation can eliminate fragmentation, reduce duplication of effort, improve information flow, enable aligned decision-making, and foster integrated teamwork.	– Cross-functional business processes may be needed to facilitate communication and collaboration. – Regular cross-functional reviews may be conducted to assess and improve collaborative business processes. – Technical solutions may be implemented to support integrated collaboration across business functions.
PRB 011	Business process defined scope	A business process has its boundary, inputs, and outputs clearly defined and documented.	Clear definitions of boundaries, inputs, and outputs ensure that all stakeholders understand the scope and responsibilities of each business process.	– Interfaces between business processes may be needed to reduce conflicts and inefficiencies. – Regular reviews and updates of business process definitions may be required. – Communication channels may be needed to disseminate this information.
PRB 012	Customer focus	A business process is designed to operate with a focus on customer needs and expectations.	A customer focused approach enhances satisfaction and sets the foundations for continuous improvements.	– Business processes may need to adapt to changing customer needs. – The customer focused approach may be limited to external customers only. – Customer feedback mechanisms may need to be designed and implemented.
PRB 013	Agility responsiveness	Business processes are flexible and responsive to the changes in external environments, market conditions, and organisational needs.	Agility enables the organisation to adapt quickly to new opportunities, threats, and changes in the external environment, maintaining competitiveness and relevance. Flexible and responsive business processes enable rapid adaptation to the external environment, market changes, customer demands, and operational needs, while maintaining efficiency and effectiveness. This adaptability is fundamental to maintaining competitive advantage and ensuring business sustainability.	– Agility could be confused with agile delivery methods. – The organisation might need to fundamentally redesign its business processes to incorporate modular components and decision points that could be easily modified or reconfigured. – The organisation may need to invest in scalable and automated solutions that support quick business process modifications without extensive redevelopment.

Item	Name	Statement	Rationale	Implications
PRB 014	Business process modularity	Business processes are modular to support flexibility, scalability, and ease of reconfiguration as business needs evolve.	Modular business processes enable the organisation to adapt more readily to changes in both the external environment (e.g., market or regulatory shifts) and the internal environment (e.g., changes in resourcing, organisational structure, or process performance). Modularity enables the components of business processes to be adjusted, replaced, or scaled independently. It also supports faster innovation, as modular components can be reconfigured or recombined to create new business processes or enhance existing ones.	– Business process modelling may prioritise modularity to enable easy adaptation and component reusability. – Integration points between modules may be clearly defined to maintain seamless interoperability across modular components. – Testing and deployment may be optimised to allow quick adjustments to individual business process modules.
PRB 015	Standardised modelling	All business processes are modelled using recognised industry standards to ensure clarity, transparency, consistency, and interoperability.	The use of industry standards for modelling business processes ensures that the resulting models enhance communication, facilitate training, support process improvement and compliance initiatives, and are well documented and easily understood. Standardised models, using recognised industry standards, also provide the transparency needed to review the security aspects of a process, to ensure flaws, gaps, and overlaps are captured.	– The adoption of ArchiMate and BPMN (Business Process Model and Notation) may be needed to model business processes at different abstraction levels. – Specific training on industry standards may be needed to ensure consistency and proficiency. – Modelling tools may be required to support the selected industry standards and provide the necessary features for effective process modelling. – Business process models may need to be consistently documented according to the selected standards, making them easily interpretable and reusable.
PRB 016	Waste minimisation	Business processes minimise waste and maximise efficiency.	Reducing waste leads to cost savings, improved resource utilisation, and streamlined operations, thereby enhancing overall productivity.	– Lean methods may be required to identify and eliminate non-value-adding activities. – Continuous improvement may be introduced to regularly review and optimise processes. – Performance metrics may be needed to measure and monitor waste, and use these insights to drive improvements. – Business process owners may need training on waste reduction practices and techniques.

Item	Name	Statement	Rationale	Implications
PRB 017	Output consistency	Business processes produce consistent and reliable outputs to meet stakeholder expectations.	Consistent outputs ensure that goods and services meet quality standards, build trust with customers and stakeholders, and reduce errors and rework, thereby enhancing overall efficiency and satisfaction.	– Standardised procedures and guidelines may be required for all business processes to ensure uniformity in outputs. – Quality control mechanisms may be needed to monitor and verify the consistency of outputs. – Performance metrics may be needed to measure the consistency and reliability of business process outputs. – Technology solutions (e.g., automation and data analytics) may be needed to support consistent business process execution and output quality.
PRB 018	Business process optimisation	Business processes are continuously optimised to eliminate defects, gaps, and overlaps, minimise waste, reduce costs, and increase speed without compromising quality.	Continuous optimisation of business processes enhances operational effectiveness and efficiency, and supports the competitiveness of the organisation by ensuring that processes function as intended and that resources are used effectively. This optimisation enables the organisation to respond more rapidly to external changes, maintain customer satisfaction, and sustain long-term cost efficiency.	– Regular performance assessments may be required to identify defects, gaps, overlaps, and other inefficiencies. – Investment in process automation and improvement technologies may be prioritised to streamline operations. – Quality assurance practices may be integrated with process optimisation efforts to prevent degradation in output quality.
PRB 019	Business processes verification	Business processes are systematically verified and redesigned to eliminate inefficiencies, gaps, and overlaps, ensuring alignment with the business services or goods they support.	Identifying and redesigning broken processes ensures that operations are efficient, effective, and capable of meeting the evolving needs of the organisation and its stakeholders.	– Regular evaluations may be required to identify broken, inefficient, flawed, or outdated business processes. – Comprehensive analysis may be needed to understand the root causes of business process inefficiencies and failures. – Stakeholders may need to be involved in the redesign to ensure that updated business processes meet their needs and expectations. – Technology may be needed to support business process tracing and simulation during redesign. – Continuous business process performance feedback may be required to ensure sustained improvements and make further adjustments as necessary.

Item	Name	Statement	Rationale	Implications
PRB 020	Business processes validation	Business processes are systematically tested against real operating conditions before and after deployment, to confirm they deliver the outcomes they were designed to achieve.	Verification confirms that a process has been correctly designed and redesigned on paper; it does not confirm that the process performs as intended once exposed to real inputs, outputs, customers, and conditions. Validating business processes through testing closes this gap, ensuring that a verified model also functions as expected in practice, and that any discrepancies between intended and actual performance are identified before they affect customers or stakeholders.	– Test scenarios may need to be developed that reflect realistic operating conditions, including edge cases and exceptions the process is expected to handle. – Piloting or staged rollout may be required before a redesigned business process is deployed at full scale. – Discrepancies identified during testing may require the process to be returned to verification for further redesign before validation can be repeated.

Table 3. SEF® Lean Version: Architectural Principles – Structural Profile – Business Domain

2.3.4 STRUCTURAL PROFILE – KNOWLEDGE DOMAIN

The knowledge domain of the structural profile includes forty-one architectural principles, which are presented in table 4.

Item	Name	Statement	Rationale	Implications
PRK 001	Information item ownership	Each information item within an information asset has a clearly defined owner accountable for its accuracy, valuation, appropriate accessibility, and compliance with the policies established for its parent information asset.	Information assets are composed of discrete information items (e.g., documents, records, individual dataset entries, and underlying files) each of which can degrade in quality or fall out of compliance independently of the information asset as a whole. Assigning ownership at the information item level ensures that accuracy, valuation, and access decisions are made by someone accountable for that specific item, rather than assumed to be covered by ownership of the information asset it belongs to.	– Assigning information item owners might be required to coordinate with the owner of the parent information asset, without assuming accountability for governance obligations that apply to the asset as a whole. – Establishing item-level ownership may increase administrative overhead where an asset contains a large number of individual items. – Disputes may arise where an item owner and an asset owner disagree on classification, valuation, or access decisions affecting the same item.
PRK 002	Information asset ownership	Each information asset has a clearly defined owner accountable for its compliance with organisational information governance, its valuation, its placement within a defined domain of trust ² , and the treatment of risks affecting it.	Information assets (e.g., datasets, databases, data warehouses, and other aggregated information structures) require accountability at the aggregate level for governance, classification, trust assignment, and risk treatment, independent of the individual items they contain, which are separately owned by information owners. Assigning ownership at the asset level ensures that access is restricted according to matched trust and trustworthiness levels ³ , and that risks to the information asset as a whole are identified and treated.	– Information asset owners might be required to define the domain of trust and access restrictions that item owners and other stakeholders must operate within. – Information asset owners may need to coordinate with multiple information owners where an asset contains items with differing valuations or compliance requirements. – Risk treatment decisions made at the asset level might override or constrain decisions an item owner would otherwise make independently.
PRK 003	Information valuation	Every information item and information asset, whether owned by the organisation where the organisation is accountable for it, or owned by a third party where the	Information items and information assets are used to generate value or to achieve contractual, regulatory, or legal compliance, and their confidentiality, integrity, and availability need to be protected by proportionate and pragmatic security controls. Without knowing the adverse impact associated with the compromise of an	– The unit of assessment used for valuation may not always be defined (e.g., whether the compromise of a single information item or of several items together is what constitutes a critical loss of confidentiality may be left unclear) affecting every classification decision that depends on that valuation.

² A conceptual area with a boundary, a level of trust, and entry and exit gates, where entities with similar objectives interact between them to form a community to add value to the organisation.

³ The level of trust is defined as the level of belief, held by a trustor at a defined point in time, that a trustee will deliver the expected behaviour. The level of trustworthiness is defined as the level of reliance, placed on the trustee at a defined point in time, to deliver the expected behaviour to the trustor.

Item	Name	Statement	Rationale	Implications
		organisation is responsible for it, is assigned a value that reflects the adverse impact its compromise would have on the organisation, with the value of an information asset reflecting the combined value of the information items it contains.	information item, it is not possible to determine the value of the information asset that contains it, since an asset composed of highly sensitive items carries a different risk profile than one composed of routine items. Without this valuation at both levels, the selection of security controls may become subjective, ineffective, impractical, and costly.	- Information that has not been captured as a discrete item (e.g., undocumented expertise or informally held records) may be difficult to value consistently. - Information items or information assets belonging to third parties may require additional valuation by the organisation, since the valuation of the third party may not reflect the adverse impact to the organisation. - The adverse impact a third party perceives from a compromise may differ from the adverse impact the organisation itself would experience, requiring the two valuations to be reconciled rather than assumed equivalent. - Where the value of an information asset is derived from its constituent information items, revaluation of the asset may be required whenever items are added, removed, or reclassified.
PRK 004	Knowledge is an asset	Knowledge and its underlying structure that make it, including information and data, are valuable assets across the organisation.	Organisations cannot survive and thrive without knowledge, which is made of refined information that is supported by data. Knowledge that remains uncaptured, whether held informally by an individual or embedded in undocumented practice, cannot be shared, reused, or protected, and its value is lost when the person holding it becomes unavailable or leaves the organisation. Capturing knowledge in explicit form, including information and data where applicable, treats it as an organisational asset rather than a personal one, and establishes the basis on which it can later be preserved and organised for use.	- Treating knowledge, and the underlying information and data, as assets may increase costs for information governance and maintenance. - There may be resistance to changing established processes to prioritise the management of information and data, including resistance from individuals reluctant to formalise or share knowledge they perceive as a source of personal value or job security. - Organisations might need to shift cultural attitudes to recognise the value of information and data alongside physical assets. - Capturing knowledge in explicit form may require dedicated effort from the individuals who hold it, competing with their operational responsibilities.

Item	Name	Statement	Rationale	Implications
PRK 005	Knowledge is retained	Knowledge is captured, preserved, and remains accessible for future use regardless of personnel changes, technology evolution, or organisational transformation.	Organisational knowledge is a critical asset that directly impacts operational efficiency, innovation, and competitive advantage. Preserving institutional knowledge prevents the loss of valuable insights, reduces redundant effort, enables knowledge transfer, and maintains business continuity. Without proper preservation, critical knowledge can be lost through staff turnover, system changes, or organisational restructuring.	– Knowledge management systems may be needed to capture and store organisational knowledge. – Documentation standards may be required for recording requirements, decisions, risks, designs, and intrusions. – Version control and change history may be needed for maintaining knowledge. – Archiving, discovery, and retrieval mechanisms may be required to ensure long-term accessibility of preserved knowledge. – Metadata standards might be defined to facilitate future discovery and context understanding.
PRK 006	Knowledge is structured	Knowledge follows organised patterns and relationships that enable effective discovery, understanding, and use.	Structure and indexing enable efficient retrieval, sharing, and application of refined information across the organisation. When knowledge is properly structured, it becomes easier to maintain, update, and integrate with other systems.	– Indexing and categorisation might be needed in knowledge repositories. – Regular updates may be required to keep content organised and relevant. – Taxonomies and classification systems may be needed to organise enterprise knowledge. – Search and retrieval mechanisms may need enhancement to leverage knowledge structures.
PRK 007	Knowledge explainability	Where knowledge or information has been produced or transformed by an Artificial Intelligence (AI) system, the basis for that output can be inspected and accounted for.	Knowledge that cannot have its derivation explained cannot be trusted, disputed, or corrected with confidence, regardless of how consistent or accurate it appears to be. Requiring that the reasoning or basis for the outputs of an Artificial Intelligence (AI) system can be inspected protects the organisation from relying on conclusions it cannot defend, and supports accountability where a generated output is challenged or found to be wrong.	– IT systems that generate knowledge or information may need to retain the inputs, model version, and reasoning steps behind a given output, rather than only the output itself. – Some Artificial Intelligence (AI) systems may be inherently difficult to explain, requiring the organisation to weigh the value of their output against the risk of relying on a conclusion that cannot be accounted for. – Explainability requirements may need to vary by the sensitivity or consequence of the decision the knowledge supports, rather than being applied uniformly to every output.
PRK 008	Common language	The organisation employs standardised acronyms and terms, aligned with industry, that are consistently understood and used for all communications across all business functions.	A common language, aligned with industry, ensures that all stakeholders have a shared understanding of acronyms and terms, facilitating clearer communication, reducing misunderstandings, and improving collaboration.	– A centralised glossary may be required as the authoritative source for acronyms and terms. – User interfaces and documentation may need to align with the centralised glossary. – Change management business processes may be required to handle updates to common acronyms and terms.

Item	Name	Statement	Rationale	Implications
PRK 009	Single source of truth	There is one authoritative source of knowledge, information, and data where they are defined and maintained.	A single authoritative source of knowledge, information, and data minimises inconsistencies, reduces errors, prevents duplication, supports coherent decision-making, reduces inefficiencies caused by reconciling conflicting sources, and fosters trust in data integrity.	– A Single Source of Truth (SSOT) may be difficult to maintain. – A Single Source of Truth (SSOT) may require consolidation of knowledge, information, and data. – Establishing a single source might restrict flexibility in data use across the organisation. – Dependency on one source could lead to bottlenecks if it fails or is compromised. – Aligning to a single source may involve significant initial migration efforts.
PRK 010	Single version of truth	There is single and current version of knowledge, information, and data produced from the authoritative source where they are defined and maintained.	A Single Version of Truth (SVOT) ensures that all decisions are based on the same, accurate knowledge, information, and data to enhance transparency, reduce confusion, eliminate conflicting interpretations, provide a unified view, reduce the need for reconciliation and duplication across multiple sources, and improve overall efficiency.	– The Single Version of Truth (SVOT) may be difficult to achieve. – Software systems and their integrations may need to be updated to reference this central version, and training may be required to assist stakeholders understand and adopt it. – Clear guidelines may be essential to maintain the integrity of the Single Version of Truth (SVOT), ensuring that any modifications are reflected across the organisation. – Business processes and software systems may require synchronisation to align all software applications and databases with the Single Version of Truth (SVOT), reducing discrepancies and ensuring all stakeholders have access to the same source of reference.
PRK 011	Information lifecycle	Information progresses through a defined set of discrete lifecycle states, connected by defined transitions, from creation through to retirement.	Managing the complete lifecycle of knowledge, information, and data assets reduces risks, maintains compliance, optimises storage and archiving costs, and ensures that assets remain valuable to the organisation.	– A lifecycle Finite State Machine may be needed to define the discrete states information can occupy and the transitions permitted between them. – Audit mechanisms may be required to track lifecycle states and transitions. – Security controls may be required for different lifecycle states.
PRK 012	Information taxonomy	Information across business functions is organised into information taxonomy groups (e.g., financial, personal, commercial, etc.) and categorised within them as information items that support business operations.	Categorising information items into defined taxonomy groups, based on their context, content, and usage, supports interoperability between business processes and software systems, enhances information discoverability, enables information consistency, and improves communication.	– Information taxonomy groups may be subject to frequent updates to support evolving business processes. – Information taxonomy may be confused with information classification or database schemas. – Information items may be confused with business objects, though the two refer to the same underlying unit viewed in different contexts. A business object is the unit exchanged between business processes (e.g., a document), while an information item is the same unit viewed as a component of an information asset (i.e., the same document).

Item	Name	Statement	Rationale	Implications
				– Business functions may find it difficult to align their corresponding information taxonomy groups to maintain uniformity in information categorisation and retrieval.
PRK 013	Information compliance	Information and its underlying data conform to the legal, regulatory, and contractual obligations that apply to them, throughout their lifecycle.	Information is frequently subject to obligations that originate outside the organisation (e.g., data protection law, sector-specific regulation, or contractual terms with customers and partners). Conforming to these external obligations protects the organisation from legal and regulatory exposure, and ensures that information can be used, shared, and retained in ways that remain defensible if challenged.	– Compliance requirements may differ by jurisdiction, information type, or contractual relationship, requiring information to be assessed individually rather than governed by a single uniform rule. – Obligations may change over time as law, regulation, or contracts are updated, requiring information handling practices to be reviewed and adjusted periodically. – Demonstrating compliance may require evidence of how information has been handled throughout its lifecycle, drawing on the auditability and lineage already established elsewhere in this domain.
PRK 014	Information classification	Information classification is based on sensitivity and purpose, with sensitivity determined by the value already assigned to the information item or information asset.	Information classification enables proper handling, storage, archiving, and use of information. It minimises the risk of misuse and supports better governance by enabling the organisation to apply specific controls and retention policies. Classification depends on information valuation, since sensitivity cannot be assessed without first knowing the adverse impact a compromise of that information would have on the organisation.	– Classification may complicate the management of information due to differing levels of sensitivity. – Improper classification may expose the organisation to unacceptable risks. – Excessive granularity in classification may introduce unnecessary complexity when introducing new technology, requiring a greater number of categories and edge cases to be accommodated. – Classification decisions may inherit ambiguity from valuation where the unit of assessment is undefined (e.g., whether it takes one document or several to warrant classification as ‘confidential’ may not be established), leaving the threshold for a given classification level unclear. – Information classification may be confused with information aggregation, though the two are distinct⁴.

⁴ Information classification applies to an individual item or information asset, while aggregation concerns the additional risk created when items or assets are combined by accumulation or association.

Item	Name	Statement	Rationale	Implications
PRK 015	Information aggregation	Where information items or information assets are combined by accumulation or association, the resulting aggregate is assessed for the risk it represents as a whole, independently of the classification already assigned to its individual components.	Combining information items or assets, whether by accumulating a large volume of similar items or by associating items that reveal more together than any one does alone, can create a level of risk that the classification of the individual components does not reflect. Assessing the aggregate independently ensures that this additional risk is identified and addressed, rather than assumed to be already covered by the classification of its parts.	- Information aggregation may be confused with information classification, though the two are distinct. - Aggregated information may require controls beyond those applied to its individual components, even where the classification level of the aggregate remains unchanged. - Identifying when accumulation or association has created a materially higher risk may be difficult, particularly where items are combined gradually or informally over time.
PRK 016	Information accessibility	Information and its underlying data are accessible across the organisation.	Accessible information and data across the organisation enable informed and timely decision-making, support transparency, enhance collaboration, streamline operations, reduce duplication of efforts, and enable a more responsive and agile organisation.	- Making information and data accessible may require significant investment in infrastructure. - Ensuring ease of access could inadvertently lead to the compromise of the confidentiality and integrity of information and data. - Misuse of information and data might occur if access controls are not meticulously enforced.
PRK 017	Information sharing	Information and its underlying data are shared between authorised stakeholders across the organisation in a controlled manner.	Information that remains confined to the individual or business function that created it cannot inform decisions elsewhere in the organisation, leading stakeholders to duplicate effort or make decisions without the full picture available to them. Sharing information between authorised stakeholders, in a controlled manner that respects its classification and any restrictions on its use, allows the organisation to draw on a single, consistent body of information for collaboration and decision making, rather than allowing isolated pockets of information to develop independently.	- Shared access could facilitate the compromise of the confidentiality or integrity of information and its underlying data if not properly managed. - Shared access could create privacy concerns if not properly controlled. - Business functions may resist sharing data due to concerns over ownership and accountability. - More stringent data-sharing policies might increase operational complexity and require ongoing oversight.
PRK 018	Information relevance	The relevance of information is prioritised to ensure that only meaningful, accurate, and actionable content is stored, accessed, and used across all business processes and software systems.	Relevant information minimises overload and enhances decision-making by focusing on valuable, contextually appropriate content. It also improves operational efficiency, supports compliance, and supports effective communication.	- Review business processes may be required to periodically assess information relevance. - Metadata frameworks may be required to monitor information timeliness and applicability, ensuring continued relevance to business needs. - Stakeholder feedback mechanisms may be needed to evaluate information usefulness. - Search systems may be required to prioritise results based on relevance.

Item	Name	Statement	Rationale	Implications
				– Analytics tools may be needed to track information usage patterns.
PRK 019	Information completeness	Information and its underlying data contain all necessary attributes to be contextually relevant and fully usable for the intended purpose.	Incomplete information can hinder decision-making, impacting organisational effectiveness. On the other hand, completeness enables accurate analysis, reduces the risk of errors and misinterpretations caused by missing or partial data, and supports more robust insights and a better understanding of trends, patterns, and dependencies.	– Striving for completeness might increase data entry time and costs. – Over-emphasis on completeness might slow down processing and reduce agility, as additional data fields are enforced. – Sufficient completeness may be needed to be defined per use case to balance quality with efficiency.
PRK 020	Open formats	Knowledge, information, and data are processed, exchanged, stored, and archived using open and standardised formats that ensure long-term accessibility, integration, and interoperability.	Open formats ensure interoperability, long-term accessibility, and vendor independence. They also facilitate seamless integration between software systems. They provide greater flexibility in selecting technology solutions, reduce conversion costs, and protect against solution lock-in.	– Format conversion tools may be needed to transform proprietary formats to open format standards. – Validation mechanisms may be needed to ensure compliance with open format specifications. – Integration frameworks may be required to handle multiple open format standards. – Exchange protocols may be required to support open format transfers.
PRK 021	Data reliability	Data are obtained from reputable and credible sources and processed to be accurate, consistent, and unbiased.	Reliable data are essential for building trust in information systems, fostering accurate and timely decisions, minimising the risks associated with misinformation, and maintaining credibility with internal and external stakeholders.	– Validation mechanisms may be required to verify that data originates from reputable and credible sources. – Error detection software systems may be needed to identify data inconsistencies. – Correction procedures may be required to address data reliability issues. – Audit systems may be needed to track data sources and modifications. – Testing frameworks may be required to validate data reliability.
PRK 022	Data uniqueness	Data are captured once at the source, uniquely identified and stored only once, reused across the organisation rather than being duplicated or recreated, and supporting a Single Source of Truth (SSOT) across systems.	Data uniqueness prevents duplication and inconsistencies across systems, enabling accurate, consistent, and reliable information for decision-making. By avoiding multiple, conflicting copies of the same data, the organisation improves data quality, enhances trust in information sources, and optimises storage and archiving.	– Master Data Management (MDM) practices and software systems may be required to maintain unique entries, enforce data deduplication, and synchronise data across business functions. – Metadata and data cataloguing systems may be needed to provide visibility into data assets and ensure there is only one authoritative source of each data element.

Item	Name	Statement	Rationale	Implications
				– Data sharing mechanisms may be required to enable organisational access. – Integration platforms may be needed to distribute source data across software systems. – Reference data systems may be needed to maintain common lookup values. – Synchronisation mechanisms may be required to keep distributed copies current. – Audit trails may be required to track data source modifications.
PRK 023	Data accuracy	Data accurately reflect the real-world scenario they represent, ensuring correctness and consistency throughout their lifecycle.	Accurate data are critical for making informed decisions, maintaining trust, and ensuring operational efficiency. When data accurately represent reality, organisations can rely on it for critical business processes, regulatory compliance, and strategic planning. Inaccurate data can lead to poor decisions, operational inefficiencies, and loss of stakeholder confidence and trust.	– Ensuring data accuracy might be time-intensive and may slow data entry processes. – Data accuracy may rely on the implementation of controls and checks at the point of entry or collection to prevent errors from being introduced. – Data validation software systems may be needed to verify accuracy at point of entry. – Quality control processes may be required to maintain data precision. – Automated checking software systems may be needed to identify data errors. – Correction workflows may be required to address inaccurate data. – Reference data systems may be needed to ensure consistent values. – Audit mechanisms may be needed to track accuracy levels over time. – Integration controls may be required to prevent accuracy degradation during data transfers.
PRK 024	Data consistency	The consistency of data prevents contradictions, duplicates, or conflicts that could arise from discrepancies or variations.	Consistency ensures that data remain stable and accurate across different time periods, sources, and variables, allowing for accurate and meaningful insights to be derived. When analysing data, consistency assists in preserving the integrity and reliability of analytical results. Inconsistent data sources may require remediation, lead to incorrect decisions, reduce system reliability, and undermine the integrity of business operations.	– When data are entered manually, there is a higher probability of human errors (e.g., typos, missing values, or incorrect formatting). – The lack of standardised data practices may not prevent individuals or business functions interpret and record data differently. – Variations in naming conventions, units, and formats can result in inconsistent data.

Item	Name	Statement	Rationale	Implications
				– Data transferred between legacy and modern systems may undergo transformations. – Achieving consistency may limit flexibility in handling data locally within business functions. – Strict enforcement of consistency may slow down data processing across software systems. – Data synchronisation patterns and mechanisms may be needed across all integrated software systems. – Additional infrastructure and processing overhead may be required to maintain consistency across distributed software systems. – Software systems may need to implement appropriate concurrency control mechanisms (e.g., locking, versioning) to prevent data conflicts and ensure ACID (Atomicity, Consistency, Isolation, and Durability) properties in transactions.
PRK 025	Data confidentiality	Data are disclosed only to parties authorised to access them, as determined by the information owner or information asset owner accountable for that data, who approve the rules under which data may be disclosed.	Data that become accessible to a party without authorisation can no longer be protected. Confidentiality depends on classification and valuation to determine who should be authorised to access a given piece of data, and requires that access be restricted accordingly, rather than made available by default and restricted only as an afterthought. The decision to authorise access remains with the information owner or information asset owner, who may delegate its daily application but remain accountable for it.	– Access control mechanisms may be required to restrict data to authorised parties, consistent with the classification and the rules approved by the accountable owner. – Encryption may be needed to protect data from disclosure while it is stored or in transit between parties. – Delegating the application of access decisions may create ambiguity about where accountability sits if unauthorised access occurs, requiring this to be clearly documented.
PRK 026	Data integrity	Data can be verified as unaltered from the point it was created, sent, or agreed, throughout its lifecycle and across every party that handles it.	Data integrity provides organisations the foundations for maintaining trust between internal and external stakeholders, and the basis for organisations to rely on their information for critical operations, compliance requirements, and decision making. Data that changes, whether by accident, error, or deliberate tampering, between the point one party creates or sends it and the point another party receives or relies on it, can no longer be trusted as representing what was originally intended or agreed. Verifying that data remains unaltered provides evidence that what was delivered is	– Change control and audit mechanisms may be required to detect unauthorised modifications and track all data changes over time. – Cryptographic verification mechanisms (e.g., one-way functions, digital signatures) may be needed to allow any party handling the data to confirm it has not been altered. – Detection and recovery mechanisms may be required to identify integrity violations and restore data to its verified state once corruption is found.

Item	Name	Statement	Rationale	Implications
			exactly what was meant, and protects the organisation from the operational failures, incorrect decisions, and regulatory violations that compromised integrity can cause.	– Integration controls may be required to preserve integrity specifically at the point data is transferred between parties or systems.
PRK 027	Data availability	Data are accessible to authorised parties whenever needed to support their intended purpose.	Data that cannot be accessed when required provides no value, regardless of how accurate, consistent, or well protected it is. Availability requires that data survive failure, remain accessible under expected conditions of demand, and be recoverable within a timeframe that matches the purpose the data serves.	– Redundancy and failover mechanisms may be required to keep data accessible despite component or infrastructure failure. – Recovery time expectations may need to be defined for different categories of data, since not all data requires the same speed of restoration. – Measures taken to protect confidentiality (e.g., strict access controls) may need to be balanced against availability, so that legitimate access is not unduly delayed or obstructed.
PRK 028	Data timeliness	Data are available as close to real-time as necessary for its purpose.	Timely data can support the organisation to respond quickly to changing conditions and make data-driven decisions in real time, whereas delayed or outdated data can result in missed opportunities, increased risks, and inefficient business processes.	– Providing timely data may require real-time processing capabilities, increasing infrastructure costs. – Timely data may require complex integrations between software systems or data sources, which can increase both the complexity of the architecture and the cost of maintaining it. – Data refresh cycles may need to be frequent, creating potential performance issues.
PRK 029	Data auditability	Data within the organisation are supported by sufficient controls and documentation to enable independent verification in support of auditing and accountability requirements.	Auditability strengthens accountability and builds stakeholder trust in data handling practices. It ensures the organisation can demonstrate compliance with regulatory obligations and mitigate risks associated with data inaccuracies or mishandling.	– Auditing may not be perceived as an independent function, risking compliance. – Auditing can increase operational overhead and complexity. – Auditing requirements might require more sophisticated logging and tracking software systems.

Item	Name	Statement	Rationale	Implications
PRK 030	Data lineage	Data are documented throughout their lifecycle, capturing their flow from origin to final use, and recording all movements, transformations, dependencies, and interactions.	Data lineage provides a transparent view of data flows, ensuring that data transformations, movements, and interactions are documented and understood. It supports informed decision making for system changes, enhances troubleshooting capability, and ensures data context and meaning are preserved across the organisation.	– Business processes and software systems may be required to capture and document data lineage, mapping the entire journey of data across systems and transformations. – Ensuring data lineage visibility may necessitate metadata management systems that provide insights into each step of the data lifecycle. – Designated personnel may be needed to oversee lineage documentation and maintain accountability for tracking data pathways.
PRK 031	Data traceability	The chain of custody for individual data elements is trackable and verifiable from the point of creation to final consumption.	Traceability is essential for regulatory compliance, security, and auditability. It provides the evidence required to prove data integrity, investigate specific data anomalies, and satisfy legal or regulatory requirements regarding how specific records were handled.	– Extensive logging mechanisms may be needed to maintain a trackable and verifiable chain of custody, which could increase storage costs and affect system processing performance. – Logging mechanisms may need to be carefully designed to avoid capturing sensitive personal data in plain text, to mitigate privacy and security risks. – Transferring data between parties may require the sender to obtain a receipt containing a message digest, providing evidence that what was received matches exactly what was sent.
PRK 032	Data validity	Data conform to predefined rules and standards that define what constitutes a valid value for their intended purpose.	Validity ensures that data meet the criteria for their intended purpose, providing the foundation for trustworthy analysis, effective decision making, and operational efficiency. Without validity, data may lead to errors, misinterpretations, and misguided actions, negatively impacting organisational outcomes and credibility.	– Enforcing data validity may require considerable setup for validation rules and standards. – Data that fail a validity check might need to be rejected or corrected, delaying workflows. – Validity checks might not be uniformly applicable across all data types, leading to complexity.
PRK 033	Data agility	Data within the organisation are adaptable, quickly accessible, and responsive to changing business needs, enabling timely and effective decision making.	Data agility ensures that the organisation can respond promptly to evolving requirements, external changes, and technological advancements. By fostering adaptable and responsive data systems, the organisation supports innovation, improves efficiency, and enhances its ability to make informed decisions under dynamic conditions.	– Supporting agility may necessitate investment in scalable infrastructure. – Flexible data practices may lead to inconsistency if not well regulated. – Agility requirements could demand rapid adaptation, challenging established protocols. – Software systems may be needed to enable real time or near real time data integration, ensuring data are up to date and information is available for timely decision making.

Item	Name	Statement	Rationale	Implications
PRK 034	Data interoperability	Data are interoperable across software systems and platforms, supporting seamless data exchange and integration.	Interoperability allows seamless integration and exchange of data, and ensures that data can flow freely across different business functions and their software systems.	– Achieving interoperability may require costly integration of legacy software systems. – Interoperable data may increase exposure risks when sharing across platforms. – Inconsistent standards across platforms may limit the effectiveness of interoperability efforts.
PRK 035	Data visualisation	Enterprise data are presented in visual formats that enhance understanding and enable effective decision-making across all organisational levels.	Effective visualisation of data increases the speed and accuracy of data interpretation, enables pattern recognition, and facilitates communication of complex information across diverse stakeholder groups. It also makes data more accessible and actionable, leading to better-informed decisions and improved operational insights.	– Additional processing and rendering capabilities may be required to support real-time data visualisation needs. – There may be a need to support the aggregation and transformation of raw data into visualisable formats. – Application software and user interfaces may need to incorporate visualisation components and libraries. – Performance requirements may need to be considered for the processing overhead of generating complex visualisations. – Storage IT systems may need to accommodate both raw data and pre-computed visualisation datasets. – Security controls may need to address sensitive data in visual presentations.
PRK 036	Data discoverability	Data and information can be identified, preserved, and produced on demand to satisfy legal, regulatory, or investigative requirements, without alteration to their original content or metadata.	Data subject to legal or regulatory proceedings must be locatable and extractable within the timeframes such proceedings require, and must be demonstrably unaltered from the point a preservation obligation arises. Data whose integrity or lineage cannot be demonstrated on demand risks noncompliance, sanctions, or an inability to defend the organisation position, regardless of how well that data is otherwise managed for operational purposes.	– Search and indexing capabilities might need to operate across archived and live data alike, rather than being limited to actively used data. – Preservation holds may need to override standard retention or deletion policies for data identified as relevant to a legal or regulatory matter. – Lineage and audit records may be required to demonstrate that produced data remains unaltered from the point a preservation obligation was applied.
PRK 037	Data provenance	The origin of data and information is recorded, distinguishing whether it was directly captured, derived through calculation or transformation, or generated by an Artificial Intelligence (AI) system.	Data and information that carry no record of their origin cannot be evaluated for the trust that should be placed in them, since directly captured, derived, and generated data each carry different evidentiary weight and different risks of error or fabrication. Recording provenance allows consumers of data to distinguish authoritative, human authored content from content that has been calculated, inferred, or produced by an	– Metadata standards may need to capture the origin type of data at the point it is created, derived, or generated, rather than relying on later reconstruction. – IT systems that combine data from multiple origin types may need to retain provenance for each component, rather than collapsing it into a single undifferentiated record. – Provenance recorded for generated data may need to identify the IT system that produced it, including the specific Artificial Intelligence (AI) model and version deployed within it, so that

Item	Name	Statement	Rationale	Implications
			Artificial Intelligence (AI) model, and to treat each accordingly.	its output can later be reassessed if either is found to be unreliable.
PRK 038	Data minimisation	Only the data and information necessary for a defined purpose is collected and retained, and no more.	Data collected or retained beyond what a defined purpose requires increases the organisation exposure to compromise, misuse, or regulatory breach without adding corresponding value. Minimisation ensures that the volume and sensitivity of data held is proportionate to the need it serves, rather than accumulating by default.	- Collection points may need to be reviewed to confirm that every data element gathered is tied to a defined purpose, rather than collected speculatively. - Retained data that no longer serves its original purpose may need to be identified and removed, in coordination with the lifecycle management already established for information assets. - Minimisation may conflict with other objectives (e.g., reusability or analytics) requiring these to be balanced rather than assuming minimisation always takes precedence.
PRK 039	Data portability	Data can be extracted and provided to another IT system or party in a usable, structured form, without dependence on the IT system in which it currently resides.	Data that can only be accessed or understood within the IT system that created them tie the organisation to that IT system indefinitely, and prevent data from being verified, reused, or transferred elsewhere. Portability, built on the open formats and interoperability already established elsewhere in this domain, ensures data can be moved on request without being distorted, lost, or made unusable in the process.	- Export mechanisms may need to be built and maintained for data that are otherwise only ever accessed through their native IT system. - Attempting to exercise portability may expose gaps in how the open formats principle was actually applied, since data that were not stored in a genuinely open or well-structured format may prove difficult to extract in a usable form even though the principle was nominally followed. - Requests for portability may need to be reconciled with confidentiality and access control requirements, so that data are not exposed to unauthorised parties in the course of being extracted.
PRK 040	Data non-repudiation	A party cannot deny having sent, received, or authored a specific piece of data, once evidence of that action has been established.	Data whose sender, recipient, or author can later deny involvement provides no reliable basis for resolving disputes, enforcing agreements, or establishing accountability. Non-repudiation, building on the traceability and cryptographic verification already established for data integrity, ensures that an action taken with respect to a piece of data can be attributed to a specific party with evidence that party cannot credibly dispute.	- Cryptographic signatures or verified receipts may be needed at the point data is sent, received, or authored, to establish evidence a party cannot later deny. - Retaining this evidence may need to extend beyond the life of the IT system that generated it, so that a dispute arising later can still be resolved. - Non-repudiation may be difficult to achieve where data are authored or transmitted through shared accounts or automated IT systems acting on behalf of several people, requiring clearer attribution at the point of action.

Item	Name	Statement	Rationale	Implications
PRK 041	Metadata is essential	The attributes of information are described through the use of metadata.	Metadata provides context, improves findability, enhances usability, improves data integration, describes key attributes (e.g., data origin, structure, format, and usage), which enhances data quality, discoverability, and governance.	– Processing and capturing detailed metadata could increase data management complexity. – Excessive metadata requirements may lead to data entry burden and accuracy issues. – Maintaining metadata can require significant ongoing administrative effort.

Table 4. SEF[®] Lean Version: Architectural Principles – Structural Profile – Knowledge Domain

2.3.5 STRUCTURAL PROFILE – APPLICATION DOMAIN

The application domain of the structural profile includes eighteen architectural principles, which are presented in table 5.

Item	Name	Statement	Rationale	Implications
PRA 001	System ownership	Each application, whether developed internally or acquired from vendors, has a designated system owner accountable for its trustworthiness, ongoing maintenance, management, and performance throughout its lifecycle, from creation or acquisition to disposal.	System ownership ensures clear accountability for the alignment of an application with business objectives, and for maintaining its trustworthiness and a minimal attack surface throughout its lifecycle, from development or acquisition until its disposal.	– System ownership might result in siloed behaviours, limiting cross-system integration and collaboration. – Establishing clear system ownership roles might require changes in organisational structure, reporting lines, and business processes. – System owners might be accountable for vendor relationships, licensing decisions, and system lifecycle planning, requiring appropriate skills and authority.
PRA 002	Application software valuation	Every application software, whether developed internally, procured from a vendor, or operated by a third party, is assigned a criticality level that reflects the adverse operational and financial impact its failure, degradation, or unavailability would have on the organisation.	Applications support business processes and manage information assets. Their failure, degradation, or compromise directly impacts revenue, operational continuity, and regulatory compliance. Without a clear criticality valuation on their integrity and availability, decisions about resilience, performance, and support become subjective and inconsistent. An application supporting a core revenue process requires higher availability and integrity than one used for internal reporting. Valuation ensures proportionate investment in reliability, security, and recovery.	– The unit of assessment (i.e., individual application vs. application cluster) may need to be clearly defined to avoid ambiguity in criticality classification. – Applications that support multiple business processes might require aggregated criticality scoring that reflects the highest-impact process they enable. – Software as a Service (SaaS) offerings might need to be subject to the same criticality assessment, as the organisation remains accountable for the business outcomes they support. – Revaluation of application criticality might be required whenever the underlying business processes or information assets it supports or manages are reclassified or retired. – Criticality levels might need to directly inform Service Level Agreements (SLAs), Recovery Time Objectives (RTOs), Recovery Point Objectives (RPOs), testing frequency, and change management rigour.

Item	Name	Statement	Rationale	Implications
PRA 003	Business value	Application software contributes directly to business objectives and delivers measurable value by supporting business processes and managing the information and data those processes depend on.	Requirements flow down from business services, to business processes, to the information and data those processes depend on, and finally to the application software that supports them. Application software investments, whether custom developed or vendor acquired, need to be justified through this chain rather than through requirements originated at the application level itself. When application requirements are not aligned with the layers above, they are instead pushed upward to justify the application after the fact, creating a silo that serves the software rather than the business need it was meant to support.	– Application software that does not trace to a business process or information and data requirement may be deprioritised or phased out. – Frequent changes in business processes or information and data requirements could necessitate regular application software updates. – Evaluation criteria are needed to confirm that application software requirements originate from business service, process, and data requirements, rather than being defined independently at the application level. – The organisation might need to establish clear methods for tracing application software requirements back through business processes to the business services and data they were derived from.
PRA 004	Consistency of outputs	Application software ensures consistent outputs, whether deterministic or non-deterministic, to maintain reliability and trust in decision-making processes.	A deterministic application produces the same output every time it is given the same input (e.g., a payroll calculation engine that always returns the same net pay for a given set of inputs). A non-deterministic application may produce different outputs from the same input (e.g., a machine learning model that returns varying recommendations as it continues to learn, or a system that incorporates randomness or real-time external data). Output consistency, in this context, does not mean identical results in both cases; it means that application software, whether developed internally or acquired from vendors, and whether deterministic or non-deterministic, produces results that remain within expected and explainable bounds, which is crucial for maintaining business process integrity and user confidence.	– Output consistency may not be achieved by non-deterministic applications. – Output consistency might drive the need for improved monitoring and testing of both deterministic and non-deterministic applications. – Quality assurance and quality control business processes may need to be adapted to handle both deterministic and non-deterministic applications. – Requirements and testing scripts might need to clearly define acceptable output variations for different types of application of application software (i.e., deterministic versus non-deterministic).

Item	Name	Statement	Rationale	Implications
PRA 005	Service automation	Where a business service can be delivered through application software instead of a manual business process, the automated delivery replaces or supplements the manual one, provided it continues to meet the same business service requirements.	Business services are sometimes first delivered through manual business processes (e.g., a customer opening a bank account at a branch) before application software is introduced to deliver the same service directly (e.g., opening the account online). Automating delivery in this way can improve speed, consistency, and cost efficiency, but only if the automated version continues to satisfy the requirements originally defined for the business service, rather than defining a new, narrower version of it.	- Existing manual business processes may need to be documented and analysed before automation, to ensure the automated version reproduces the outcomes the business service is required to deliver. - Some business services may need to retain a manual channel alongside the automated one, where customers are unable or unwilling to use application software directly. - Business process owners and system owners may need to coordinate closely during the transition, to ensure accountability for the business service is not lost between the manual process being retired and the application software taking over.
PRA 006	Automation equivalence	An automated business service delivers value to the customer that is at least equivalent to the manual business process it replaces, across quality, completeness, and trust.	Automating a business service can be pursued for cost or efficiency reasons without verifying that the resulting experience still meets the standard the manual process previously delivered. Requiring equivalence, rather than assuming it, protects against automation quietly reducing what a customer actually receives, such as a loss of the judgement, flexibility, or reassurance a person previously provided during the manual process.	- Automated business services may need explicit acceptance criteria that describe what equivalent or better outcomes look like, before being approved to replace a manual process. - Customer feedback may need to be gathered specifically to compare the automated experience against the manual one it replaced. - Exceptions handled informally by a person during the manual process may need to be explicitly designed into the automated business service, rather than left unaddressed.
PRA 007	Software flexibility	Application software accommodates change with minimal disruption, allowing for modifications, enhancements, and adaptations to new requirements while maintaining system stability and performance.	Flexibility supports application software to adapt easily to change, reduce maintenance costs, speed up delivery of new features, and extend the lifespan of the application software.	- Software flexibility may require greater abstraction, modularity, and loose coupling, which can introduce additional overhead and complexity, affecting software performance. - The organisation might need to develop comprehensive evaluation criteria for assessing the flexibility of potential application software acquisitions, which could include examining Application Programming Interfaces (APIs), integration capabilities, configuration options, and vendor roadmaps before making purchasing decisions. - Vendor management may need to track and try to influence vendor product roadmaps, since the ability to customise and extend acquired application software often depends on vendor support and release timing. - The organisation might need to maintain a balance between using vendor-provided customisation options and developing custom extensions

Item	Name	Statement	Rationale	Implications
PRA 008	Software usability	Application software is designed with user needs in mind, providing intuitive interfaces that reduce cognitive load, enhance user experience, and improve productivity.	Usability directly impacts user adoption, productivity, and the overall success of application software. Good usability reduces errors, speeds up task completion, and ensures that application software, regardless of whether it is developed in-house or vendor acquired, and regardless of whether its behaviour is deterministic or non-deterministic, effectively serves its intended users.	– Comprehensive usability requirements could influence both vendor selection criteria and internal development practices. – Usability may require regular user feedback and testing to ensure requirements are met regardless of application software source or behaviour. – User interface design may need to consider special requirements for non-deterministic applications, which in turn could lead to new approaches for presenting Artificial Intelligence (AI) driven results and might require additional guidance features to help users understand varying outputs.
PRA 009	Software modularity	Application software is structured into independent, interchangeable modules that encapsulate distinct functions, enabling easier maintenance, updates, and scalability while supporting both custom-developed and vendor-acquired solutions.	Modularity is fundamental to managing application software complexity and change, enables incremental improvements, and provides flexibility in selecting between custom development and vendor solutions for different application modules.	– Integration between modules may require standard interfaces and communication channels. – Interoperation between modules in untrusted environments may require security controls. – The organisation might need to establish clear module boundaries that apply to both custom-developed and vendor-supplied modules, which could influence vendor selection criteria and may require additional integration effort to ensure consistent interaction between different modules. – The application software landscape may become more diverse, which in turn could require more complex governance to manage the overall application lifecycle. – The organisation could need to invest in robust integration platforms and may need to develop expertise in managing hybrid solutions combining custom and vendor modules.
PRA 010	Software reusability	Application software components are designed to be reusable across multiple systems and contexts.	Reusable software components reduce development time and costs by eliminating redundant effort. They promote consistency in functionality and behaviour across systems, simplify maintenance by centralising changes, and enable faster delivery of new capabilities by leveraging proven components rather than building from scratch.	– Reusability requires upfront investment in designing generalisable components rather than point solutions, potentially increasing initial development time. – Reusable components require robust documentation, versioning, and governance to ensure they are discoverable and properly maintained over time. – Changes to reusable software components may have widespread impact across multiple systems, requiring careful change management and compatibility testing.

Item	Name	Statement	Rationale	Implications
PRA 011	Software interoperability	Application software is capable of exchanging information with other application software through standard protocols, data formats, and interfaces, regardless of its source, technology platform, or whether it was internally developed or vendor acquired.	Interoperability is the technical precondition for applications to work together. Without standard protocols, data formats, and interfaces, applications cannot exchange information reliably, regardless of how well they are otherwise designed. Establishing this interoperability allows any application, whether developed internally or acquired from a vendor, to participate in a shared technology landscape rather than requiring a custom connection to be built separately for every application it needs to work with.	– The organisation might need to establish and enforce standard communication protocols, data formats, and Application Programming Interfaces (APIs) across all application software, influencing both development practices and vendor selection criteria. – The organisation may need to incorporate integration platforms or middleware solutions that can bridge different technologies. – Vendor selection criteria might require detailed assessment of Application Programming Interfaces (APIs), data formats, and supported protocols before making purchase decisions.
PRA 012	Software integration	Application software is actually connected to other application software, so that data exchange, process flow, and functional interaction take place across the organisation in support of end-to-end business processes.	Interoperability provides the means for applications to exchange information, but that means delivers no value until it is put to use. Integration is the realised connection between applications, built on top of that means, that allows a business process to flow from one application to another without manual intervention or duplicated data entry. Both custom developed and vendor acquired applications need to be actively integrated, not merely interoperable in principle, for end-to-end business processes to function as intended.	– The organisation might need to establish enterprise-wide integration patterns that apply to both custom development and vendor solutions. – The procurement business process may need to prioritise integration, not just interoperability, when evaluating vendor solutions. – Development and implementation teams might need to focus more attention on integration testing to confirm that connected applications behave correctly as part of an end-to-end business process.
PRA 013	Low coupling	The modules of the application software are detached from each other and interoperate through corresponding interfaces.	Loosely coupled modules are easier to develop and maintain; they can be developed, built, configured, and tested in parallel; they can be modified and updated without affecting each other, and they support extensibility and scalability.	– Low coupling may introduce complexity to a software system. – Vendor acquired software may need to be assessed for coupling in the same way as internally developed software, since low coupling is not a concern limited to internal development. – Low coupling may result in inconsistencies as modules process requests differently from others. – Transactional integrity between loose coupled modules may be difficult to achieve.

Item	Name	Statement	Rationale	Implications
PRA 014	High cohesion	The modules of the application software focus on a single, well-defined purpose, encapsulating closely related functions and data to ensure maintainability, scalability, and reusability.	High cohesion is essential because it creates focused modules that are easier to understand, maintain, and modify. When modules have clear and single functionalities, they are more reliable, testable, and can be evolved independently. This focused design approach reduces complexity while improving the overall quality of the application architecture.	– Software development teams might need to invest more time in initial design phases to properly identify and define module boundaries. – Existing application software may need to be refactored to break down large, multi-purpose modules into smaller, more focused units. – Integrating acquired software systems might require detailed analysis to ensure they exhibit high cohesion.
PRA 015	Software integrity	Application software is designed, implemented, and maintained to produce trustworthy results throughout its lifecycle.	Software integrity is essential to ensure that application software, whether developed in-house or acquired from vendors, and regardless of being deterministic or non-deterministic, consistently produces trustworthy and dependable results. It safeguards against unauthorised alterations, reduces vulnerabilities, and ensures that application software operates as intended.	– Software integrity may require robust testing, monitoring, and validation to detect and address anomalies or vulnerabilities. – Software integrity might involve implementing stringent version control and security measures to prevent unauthorised modifications. – Software integrity could encourage adopting practices (e.g., code reviews and automated checks), to ensure consistency and quality across all application software types.
PRA 016	Software resilience	Application software is fault-tolerant, ensuring availability and continuity of service even during system failures or disruptions, and maintaining reliable business operations under adverse conditions.	Resilient application software is critical for maintaining business continuity and service reliability, and for ensuring that business operations remain stable even when facing technical challenges, regardless of source or processing nature. When applications can effectively handle failures and recover from disruptions, the organisation can minimise downtime, protect data integrity, and maintain service levels.	– Design decisions might need to prioritise fault tolerance and recovery. – The organisation might need to establish comprehensive resilience requirements that address different types of failures across all application software types. – Application software testing may need to simulate various failure scenarios and recovery procedures. – The organisation might need to implement automated monitoring and recovery to maintain service continuity across all application software types.
PRA 017	Software maintainability	Application software is easy to maintain, with clear code, proper documentation, and support for regular updates and defect fixes.	Maintainable software reduces operational costs, speeds up problem resolution, and extends application lifespan. When application software is well-documented and structured for maintenance, the organisation can manage updates, fix issues, and implement changes more efficiently.	– The organisation might need to establish comprehensive maintenance and documentation requirements for all application types. – Vendor selection business processes may need to evaluate long-term maintenance and support arrangements. – Development and support teams might need specialised skills for maintaining different types of application software.

Item	Name	Statement	Rationale	Implications
PRA 018	Software support	Application software is supported throughout its lifecycle with maintenance, updates, and technical assistance to ensure continued functionality and security.	Ongoing support is essential to address defects, apply security patches, adapt to changing requirements, and maintain compatibility with evolving infrastructure. Without adequate support, software becomes vulnerable to security threats, fails to meet user needs, and may cause operational disruptions that impact business continuity.	– Support arrangements may need to be established before deployment, whether through internal teams or vendor contracts with defined service levels. – End-of-life planning may be required for application software that will no longer receive support, including migration strategies and risk mitigation. – Support costs may represent a significant portion of Total Cost of Ownership (TCO), requiring ongoing budgetary commitment throughout the software lifecycle.

Table 5. SEF® Lean Version: Architectural Principles – Structural Profile – Application Domain

2.3.6 STRUCTURAL PROFILE – INFRASTRUCTURE DOMAIN

The infrastructure domain of the structural profile includes thirty-five architectural principles, which are presented in table 6.

Item	Name	Statement	Rationale	Implications
PRA 001	System ownership	Each infrastructure IT system has a clearly defined owner accountable for its maintenance, performance, security, and compliance throughout the lifecycle.	Defining system ownership ensures accountability for maintaining system reliability, security, and alignment with business objectives. It clarifies responsibilities, improves decision-making, and facilitates effective management of resources throughout the lifecycle of the IT system, from development or acquisition until its disposal.	– Owners may need to maintain oversight of IT system performance, security posture, updates, and obsolescence. – Collaboration between owners and stakeholders may be needed to align IT systems with evolving business and security needs. – Ownership assignments may create conflicts when accountability for system performance or security intersects with shared infrastructure dependencies or cross-system integration points.
PRA 002	Infrastructure IT system valuation	Every infrastructure IT system (e.g., network device, compute, storage, system software, middleware software, etc.) is assigned a criticality level that reflects the adverse operational impact its failure, degradation, or compromise would have on the organisation.	Infrastructure IT systems underpin all applications and information assets. Their failure, degradation, or compromise can cascade across multiple business processes, causing widespread disruption. Without a clear criticality valuation of their integrity and availability, decisions about redundancy, capacity, patching, and recovery become reactive and inconsistent. An infrastructure IT system supporting mission-critical applications requires higher resilience and faster failover than one supporting development or testing environments. Valuation ensures proportionate investment in reliability, security, and recoverability.	– The unit of assessment (e.g., individual server or cluster) may need to be clearly defined to enable consistent criticality classification. – Shared infrastructure IT systems that support multiple applications might need to inherit the highest criticality level of any application they support, as their failure would impact all downstream IT systems. – Platform as a Service (PaaS) and Infrastructure as a Service (IaaS) offerings might need to be subject to the same criticality assessment, as the organisation remains accountable for the business outcomes they support even when the underlying infrastructure is externally operated. – Revaluation of infrastructure criticality might be required whenever the supported applications or information assets are reclassified. – Criticality levels might need to directly inform architecture decisions (e.g., active-active versus active-passive), capacity planning, maintenance windows, and IT Incident Response and Security Response prioritisation.

Item	Name	Statement	Rationale	Implications
PRN 003	Modularity	The infrastructure consists of modules, allowing easy upgrades, replacements, and scaling of individual parts.	Modular design enables targeted updates and independent scaling, whereas monolithic infrastructure creates rigid dependencies that hinder evolution and scale.	– Holistic management might require additional coordination between module teams. – Storage IT systems could need extra capacity to handle module independence. – Testing environments may demand more resources to validate module interactions.
PRN 004	Scalability	The infrastructure scales efficiently, accommodating future growth in users, data, and workloads within defined boundaries.	Scalability ensures that as demand grows, the infrastructure can expand without incurring excessive costs. This flexibility allows the organisation to meet future requirements while maintaining control over spending and resource allocation, avoiding over-provisioning or underutilisation.	– Capacity planning may need to focus on anticipating growth trends and scaling incrementally to align with actual demand. – Cost optimisation techniques may need to be employed to ensure that as the infrastructure scales, it does so without overspending on unused resources. – Scalable solutions may need to allow resources to be added or removed as workload requirements change.
PRN 005	Elasticity	The infrastructure automatically adjusts based on real-time demand metrics, scaling both vertically and horizontally within defined boundaries.	Elasticity ensures that infrastructure responds to demand as it happens, rather than only as part of planned, incremental scaling. This reduces the risk of both service degradation during sudden spikes in demand and resource waste during periods of low demand.	– Performance monitoring might require sophisticated predictive analytics to anticipate scaling needs ahead of demand. – Monitoring systems might require additional storage capacity to capture and analyse real-time scaling metrics. – Resource pools could need significant headroom to accommodate sudden expansion. – Network capacity could need over-provisioning to accommodate sudden scaling events. – Backup systems may require additional flexibility in scheduling to accommodate infrastructure that expands and contracts dynamically. – Cost models may become more complex as capacity varies rather than remaining fixed.
PRN 006	Resilience	The infrastructure is fault tolerant, detecting failures as they occur and recovering from them quickly to limit their impact on service.	Failures are inevitable in any infrastructure, regardless of how well it is designed. Resilience ensures that when a failure does occur, it is detected and contained quickly, and that recovery restores normal operation with minimal disruption, rather than allowing a single failure to cascade into extended downtime.	– Recovery business processes may be required to ensure swift restoration of IT services after a disruption. – Monitoring and alerting systems may need to be in place to detect and respond to failures as they happen. – Failure scenarios may need to be tested regularly to confirm that recovery mechanisms perform as expected.

Item	Name	Statement	Rationale	Implications
PRN 007	High availability	The infrastructure ensures that critical IT systems remain accessible to users with minimal downtime, through redundancy that prevents a single component or node failure from taking the system out of service.	Where an IT system cannot tolerate any noticeable interruption, redundancy must exist before a failure occurs, rather than relying on recovery after the fact. High availability protects mission critical systems from component level outages by ensuring no single failure can remove the system from service.	– Redundant and failover components may be needed across critical IT systems to eliminate single points of failure. – Additional infrastructure cost may be incurred, since redundancy typically requires maintaining duplicate capacity that is not otherwise needed. – Regular testing of failover configurations may be needed to confirm that redundancy performs as expected during an actual outage.
PRN 008	Performance optimisation	The infrastructure is optimised for performance, minimising latency and maximising throughput while balancing resource utilisation.	Optimising performance ensures that IT systems operate at their peak efficiency, delivering fast response times and handling workloads effectively. This improves user experience, supports business agility, and reduces operational costs by making the most efficient use of available resources.	– Monitoring tools may need to be implemented to continuously track system performance and identify areas for improvement. – Resource allocation and scaling may need to be dynamically managed to maintain optimal performance during varying loads. – Performance tuning may be an ongoing process, balancing latency, throughput, and resource use to meet evolving business needs.
PRN 009	Cost efficiency	The infrastructure minimises costs by optimising resource use, reducing waste, and ensuring efficient scaling.	Cost-efficient infrastructure maximises Return On Investment (ROI) by ensuring that resources are used effectively and waste is minimised. This enables organisations to maintain operational effectiveness while keeping expenditures manageable, supporting long-term sustainability.	– Resource utilisation may be continuously monitored to identify underused or over-provisioned assets, allowing for reallocation or decommissioning. – Scaling strategies may be dynamic, enabling the infrastructure to adjust capacity based on demand without over-provisioning. – Automation and optimisation may be leveraged to streamline operations and reduce the need for manual intervention, driving further cost reductions.
PRN 010	Cost attribution	Infrastructure consumption is metered and attributed to the business service, product, or organisational unit that generates it, so that infrastructure costs can be traced to their source.	Shared infrastructure that is billed as a single, undifferentiated cost gives the organisation no way to know which business service, product, or unit is actually driving that spend. Metering and attributing consumption makes infrastructure cost transparent and traceable, supporting informed decisions about where investment is justified and where consumption should be reduced.	– Metering mechanisms may be needed to record infrastructure consumption at a level of detail fine enough to attribute it accurately. – Tracking mechanisms might require additional storage capacity. – Business services or units that share infrastructure may need agreed rules for how joint consumption is divided between them.

Item	Name	Statement	Rationale	Implications
				– Attribution reporting may need to be reconciled regularly against actual infrastructure billing to confirm it remains accurate over time.
PRN 011	Interoperability	The infrastructure supports seamless interoperation across physical, virtual, and cloud environments, ensuring compatibility and flexibility.	Interoperability enables efficient data exchange and operational continuity across diverse environments, allowing organisations to leverage existing investments and adapt to changing needs. It fosters flexibility, scalability, and improved resource utilisation by enabling diverse systems to work together seamlessly.	– Integration tools and protocols may be standardised to ensure smooth interaction between on-premise and cloud infrastructure. – Infrastructure components may be designed to support cross-environment compatibility, reducing friction in hybrid or multi-cloud deployments. – Compatibility testing and ongoing validation may be necessary to ensure consistent performance across different platforms and environments.
PRN 012	Automation	The infrastructure management is automated where possible to reduce manual intervention, improve consistency, and enhance operational efficiency.	Automation minimises human error, accelerates routine tasks, and ensures consistent application of configurations. It enhances scalability, reduces operational costs, and allows IT teams to focus on higher-value activities by eliminating repetitive manual business processes.	– Business processes such as provisioning, monitoring, and patch management may need to be streamlined through automation tools. – Personnel roles may need to evolve to focus on designing and maintaining automation workflows rather than performing repetitive tasks. – Automation software systems may need to be monitored to ensure accuracy and quickly address any errors or failures in execution.
PRN 013	Standardisation	Standardised technologies and configurations are used to simplify management, improve compatibility, and reduce complexity.	Standardisation reduces operational overhead by minimising variability, enhancing compatibility across IT systems, and simplifying troubleshooting. It fosters scalability, streamlines procurement, and lowers costs while supporting consistent implementation of security and compliance measures.	– Technology stacks and configurations may need to be consolidated to align with approved standards across the infrastructure. – Maintenance and support efforts may need to be streamlined, as fewer variations require specialised expertise or customised solutions. – Vendor relationships and procurement business processes may become more efficient due to reduced variability in hardware and software. – Template maintenance could require dedicated resources.

Item	Name	Statement	Rationale	Implications
PRN 014	Disaster recovery	The infrastructure includes disaster recovery mechanisms to ensure critical data and IT systems are protected and recoverable in case of catastrophic events.	Disaster recovery mechanisms minimise the impact of catastrophic events by ensuring the timely restoration of critical IT systems and data. This reduces downtime, safeguards organisational continuity, and meets legal, regulatory, or business requirements for resilience.	– Budget and resources may need to be allocated to implement and maintain disaster recovery solutions, including backups, redundancy, and failover systems. – Disaster recovery plans and IT systems may need to be periodically tested and updated to ensure effectiveness in actual recovery scenarios. – Dependencies between IT systems and data may need to be documented to prioritise recovery efforts for critical services.
PRN 015	Virtualisation	Infrastructure leverages virtualisation to maximise resource efficiency, improve flexibility, and simplify management by abstracting physical hardware.	Virtualisation allows for better resource utilisation by enabling multiple virtual instances to run on a single physical server. This enhances flexibility, reduces hardware costs, and simplifies infrastructure management, all while providing scalability and isolation for different workloads.	– Infrastructure resources may need to be dynamically allocated to meet workload demands while optimising the use of underlying hardware. – Virtualisation technologies may need to be compatible across environments, supporting both legacy and modern applications. – Management software systems may need to be implemented to monitor and control virtualised environments, ensuring performance, security, and compliance.
PRN 016	Edge computing	The infrastructure supports edge computing where needed, enabling processing closer to data sources to reduce latency and enhance real-time capabilities.	Edge computing improves performance, reduces bandwidth usage, and supports critical real-time operations by processing data near its source. This approach enhances user experiences and supports modern applications requiring low-latency responses.	– Infrastructure may need to accommodate decentralised computing and storage architectures to support edge locations. – Security measures may be extended to edge environments, addressing potential vulnerabilities in distributed setups. – Application software may be designed to handle distributed processing while maintaining data consistency.
PRN 017	Centralised management	The infrastructure is managed centrally to provide visibility, control, and consistency across physical and virtual environments.	Centralised management streamlines operations, reduces administrative overhead, and enhances security by ensuring consistent application of configurations. It enables better monitoring, faster issue resolution, and improved scalability by consolidating control into a unified platform.	– Management software systems may need to support integration across diverse environments to provide a single point of oversight. – Configurations may need to be standardised to ensure uniformity across all managed IT systems. – Administrators may need access to centralised analytics to monitor performance and detect anomalies efficiently.

Item	Name	Statement	Rationale	Implications
PRN 018	Attestation	The infrastructure supports attestation mechanisms to verify the integrity and compliance of hardware, software, and configurations, ensuring trustworthiness and alignment with security requirements.	Attestation enhances the authenticity and integrity by verifying that infrastructure components operate as intended and comply with established policies. This ensures IT systems remain free from unauthorised modifications and supports regulatory compliance, reducing risks to critical operations.	– Software systems may require to incorporate mechanisms to validate the integrity of configurations and software during deployment and runtime. – Compliance checks may need to be automated and integrated into the management lifecycle to detect deviations promptly. – Attestation event data may need to be logged and monitored to provide evidence for audits and incident investigations.
PRN 019	Infrastructure as code	Every compute, storage, archival, and network component originates from version-controlled code repositories rather than manual processes.	Manual infrastructure management leads to configuration drift, undocumented changes, and irreproducible environments. Code-driven infrastructure ensures consistency and maintains a clear audit trail.	– Training investment might increase significantly as teams transition from manual to coded infrastructure. – Deployment times could lengthen initially as code review business processes replace direct changes. – Version control systems may require additional storage capacity for infrastructure code history. – Infrastructure as Code (IaC) may apply to virtual infrastructure only.
PRN 020	Bimodal infrastructure	The infrastructure support both traditional stable workloads and fast-changing innovative application software through distinct but integrated environments.	Different business needs require different infrastructure speeds and stability levels. Bimodal infrastructure enables both reliable operations and rapid innovation without compromising either.	– Resource allocation might require sophisticated partitioning between stable and agile environments. – Management software systems could need separate interfaces for each operational mode. – Integration points may demand additional redundancy and failover capabilities.
PRN 021	Resource optimisation	Compute and storage resources dynamically allocate and release based on actual consumption patterns and predictive analytics.	Resource optimisation balances cost efficiency with performance requirements. Static allocation wastes capacity through over-provisioning or causes performance issues through under-provisioning. Dynamic allocation based on consumption patterns and predictive analytics matches resources to actual demand, maximising utilisation, reducing costs, and enabling rapid response to changing requirements.	– Analytics software systems might demand dedicated compute resources. – Storage performance could vary as resources are redistributed. – Management overhead may increase with optimisation complexity.

Item	Name	Statement	Rationale	Implications
PRN 022	Multi-region design	Compute and storage IT systems are deployed across multiple regions with consistent management capabilities, so that the failure of an entire region does not remove the service from availability	High availability within a single region cannot protect against the loss of that region as a whole, whether from a widespread outage, disaster, or infrastructure failure affecting the entire location. Deploying across multiple regions removes this single point of failure at the regional level, and additionally reduces latency by serving users from a region closer to them, while supporting data residency requirements where data must remain within a specific jurisdiction.	– Synchronisation between regions may add complexity to maintaining data and configuration consistency. – Storage and infrastructure costs could increase, since capacity is duplicated across each region rather than maintained in one. – Management processes may need to account for coordinating deployments, monitoring, and failover across regions rather than within a single location.
PRN 023	Archive accessibility	Archived data remain accessible through standard interfaces with defined discovery functions and clear retrieval time expectations.	Accessible archives preserve data value for compliance and business needs while achieving storage cost savings. Inaccessible archives become data graveyards that fail regulatory requirements and business utility. Clear retrieval expectations enable appropriate planning while balancing cost against accessibility requirements.	– Retrieval software systems might need significant buffer capacity. – Access patterns could impact production performance. – Index maintenance may require dedicated resources.
PRN 024	Storage tiering	Storage systems automatically move data between performance tiers based on access patterns and retention policies.	Storage tiering optimises cost versus performance by placing frequently accessed data on high-performance storage and moving inactive data to cheaper tiers. Single-tier storage forces a choice between excessive costs or poor performance. Automated tiering eliminates manual classification and adapts to changing usage patterns.	– Movement operations might impact available bandwidth, particularly when large volumes of data are moved between tiers during peak usage periods. – Classification systems could need regular refinement, as access patterns and retention requirements change over time and previously accurate tiering rules become outdated. – Access latencies may vary significantly depending on the tier a piece of data currently resides in, requiring applications and users to tolerate slower retrieval for infrequently accessed data.
PRN 025	Compute flexibility	Compute resources support multiple processing types and workload patterns through standardised orchestration.	Flexible compute enables efficient resource utilisation across diverse workloads without requiring specialised infrastructure for each type. Fixed configurations lead to over-provisioning for peak requirements or performance constraints during demanding periods. Standardised orchestration maintains operational consistency while supporting workload diversity.	– Orchestration software systems might require additional complexity. – Resource allocation could need sophisticated algorithms. – Performance profiles may vary more widely.

Item	Name	Statement	Rationale	Implications
PRN 026	Backup integration	Backup business processes integrate directly with compute and storage IT systems through automated workflows.	Integrated backup ensures consistency and completeness through automation, eliminating human error and reducing production system impact. Manual processes are unreliable, often miss critical data, and may degrade performance through uncoordinated operations. Integration enables rapid verification of backup integrity.	– Storage IT systems might need substantial additional capacity. – Network bandwidth could require careful scheduling. – Recovery testing may demand dedicated environments.
PRN 027	Workload isolation	Different compute workload types operate in isolated resource pools while sharing common management interfaces.	Workload isolation prevents resource contention and ensures predictable performance. Without isolation, resource-intensive workloads can starve other applications, causing cascading failures. Isolation also improves security by limiting lateral movement and simplifies troubleshooting by containing issues within boundaries.	– Resource efficiency might decrease with isolation. – Management software systems could need additional complexity. – Capacity planning may require more granular approaches.
PRN 028	Resource monitoring	Every compute and storage resource emits detailed utilisation and performance metrics for analysis.	Comprehensive monitoring enables proactive issue identification and optimisation before service impact occurs. It supports informed decisions about capacity, performance, and costs. Limited visibility forces reactive management where problems are addressed only after affecting services, increasing downtime and degrading user experience.	– Data storage might require significant capacity. – Analytical systems could need dedicated resources. – Network traffic may increase substantially.
PRN 029	Hosting environment	Each software system is hosted on a dedicated, purpose-specific hosting infrastructure with tailored resource allocation and access controls according to the lifecycle state where the software system falls.	Specialised hosting ensures optimal performance, security, and isolation for each stage of the software system development, testing, and deployment lifecycle.	– Infrastructure teams might need to design distinct hosting for each environment. – Resource allocation could vary significantly between hosting environments. – Compliance and security teams may require separate monitoring and access management for each hosting environment.

Item	Name	Statement	Rationale	Implications
PRN 030	Environment identification	Each environment has a clear, unambiguous identity with defined purpose, access controls, and classification criteria.	Precise environment identification ensures proper usage, security segregation, and clear operational boundaries between development, testing, pre-production, and production environments.	– Metadata software systems might require extensive customisation to ensure datasets are used accordingly. – Security teams may need to develop comprehensive access control matrices. – Business processes may need significant elaboration to manage environment lifecycles.
PRN 031	Immutable deployment	The promotion of software systems, their modules and components, between environments is immutable and versioned, with no runtime modifications allowed.	Immutability prevents configuration drift by ensuring deployed software cannot be modified at runtime. This guarantees that tested configurations reach production unchanged, enables reliable issue reproduction across environments, and supports rapid rollback when problems occur. Versioned artefacts provide clear deployment lineage for audit and compliance purposes.	– Existing deployment business processes might need comprehensive redesign. – Container registry systems could support more robust versioning. – Development teams may need to restructure application software configuration management.
PRN 032	Environment fidelity	Pre-production environments and their hosting software systems are exact replicas of production environments.	Maximum similarity between pre-production and production environments minimises deployment risks and unexpected behavioural variations.	– Storage IT systems might need substantial additional capacity. – Licensing costs could increase dramatically. – Configuration management software systems may require advanced synchronisation mechanisms.
PRN 033	Ubiquitous decentralisation	Environment infrastructure is distributed, resilient, and capable of autonomous operation without centralised dependencies.	Decentralisation increases system reliability, reduces single points of failure, and supports geographic distribution and scalability.	– Teams might invest significantly in distributed system architectures. – Infrastructure groups may need advanced service mesh capabilities. – Monitoring systems could become more complex in observability requirements.

Item	Name	Statement	Rationale	Implications
PRN 034	Promotion environment	All software promotions between environments (i.e., development, testing, pre-production, and production) are managed exclusively through a centralised promotion environment that orchestrates and controls the transition process.	A centralised promotion environment ensures that software moves between environments through controlled, standardised processes rather than ad-hoc transfers. This prevents unauthorised or untested code from reaching production, enforces approval workflows and quality gates, and provides complete audit trails of what was promoted, when, and by whom. Without centralised control, software can bypass critical environments or testing stages, introducing risks and making it difficult to track deployment lineage or maintain compliance with change management requirements.	– The organisation might need specialised middleware for managing promotions. – Compliance teams may require enhanced tracking and logging capabilities. – DevOps teams may need to use additional software systems to implement promotion workflows.
PRN 035	Environment separation	Each environment is logically and functionally isolated, with strict boundary controls and minimal interdependencies.	Logical separation prevents unintended interactions, reduces cross-environment contamination, and enables independent scaling, configuration, and management of each environment.	– Network infrastructure might require complex segmentation using Virtual Local Area Networks (VLANs) or software-defined networking. – Identity management systems may need to implement granular role-based access controls. – Cloud computing may need multi-tenant isolation mechanisms.

Table 6. SEF® Lean Version: Architectural Principles – Structural Profile – Infrastructure Domain

2.3.7 STRUCTURAL PROFILE – FACILITY DOMAIN

The facility domain of the structural profile includes sixteen architectural principles, which are presented in table 7.

Item	Name	Statement	Rationale	Implications
PRF 001	Facility ownership	Each facility (e.g., offices, datacentres, outlets, warehouses, or other locations where business operations occur) has a clearly defined owner accountable for its environmental controls, physical protection, supporting infrastructure, and continuity throughout its lifecycle.	Facilities house the IT systems, people, and operations the organisation depends on, and a facility that lacks environmental control, physical protection, or continuity planning places everything it houses at risk, regardless of how well those housed systems and operations are managed independently. Assigning ownership ensures a single accountable party governs the facility from acquisition or construction through to disposal or lease return.	– Facility owners may need to approve structural or layout changes, and the transition of a facility into active operations, before either can proceed. – A Disaster Recovery Plan (DRP) may be required for each facility, approved and maintained by its owner, to ensure continuity if the facility is compromised. – Facility owners may retain accountability for compliance, risk, and issues affecting the facility even where responsibilities such as daily operations are delegated to others.
PRF 002	Accessibility	Facilities ensure accessibility for employees, customers, and visitors, including people with disabilities.	Accessible facilities promote inclusivity and compliance with disability access laws, enhancing employee and visitor experience.	– Accessibility may require specific design modifications, increasing construction costs. – Accessibility may constrain design choices or require trade-offs with space optimisation. – Accessibility may require regular assessments to ensure compliance with accessibility standards.
PRF 003	Scalability	Facilities support future growth by being scalable, ensuring they can accommodate increased capacity without major redesign.	Scalability allows facilities to evolve with the business, avoiding frequent and costly upgrades while supporting long-term business continuity.	– Scalability may require flexible infrastructure and space planning to allow expansion. – Scalability may increase initial design complexity to accommodate future growth. – Periodic capacity assessments may be necessary to ensure scalability remains relevant.
PRF 004	Redundancy	Facilities incorporate redundancy and failover systems to ensure continuous operation in case of hardware or infrastructure failure.	Redundancy minimises the risk of downtime, ensuring business continuity and the availability of critical systems.	– Redundancy may increase facility complexity and operational costs due to the need for backup systems. – Redundancy may require ongoing maintenance to ensure backup systems are functional. – Redundancy may result in longer lead times for infrastructure changes or upgrades.

Item	Name	Statement	Rationale	Implications
PRF 005	Flexibility	Facilities are designed with flexibility to adapt to changing business needs, including space and equipment requirements.	Flexibility allows the facility to quickly adjust to new technologies, business operations, or changes in scale.	– Design flexibility might require additional space and modularity in infrastructure. – Flexibility could lead to higher initial costs due to the need for adaptable systems. – Ongoing investment in reconfiguring spaces might be required.
PRF 006	Compliance	Facilities meet all relevant regulatory, safety, and legal requirements to ensure compliance with regulations and laws.	Compliance ensures that facilities operate within legal boundaries, avoiding penalties and ensuring the safety of employees and assets.	– Compliance may necessitate regular audits and updates to meet evolving regulations. – Compliance may restrict design options due to strict regulatory requirements. – Compliance may require specialised expertise in legal and regulatory compliance for design and operations.
PRF 007	Sustainability	Facilities minimise environmental impact through sustainable practices and materials.	Sustainable facilities reduce environmental impact, reduce the carbon footprint, contribute to corporate social responsibility, and can lower operational costs in the long run.	– Sustainability could increase initial construction costs but provide long-term savings in utilities and maintenance. – Sustainability may require ongoing monitoring and adherence to sustainability goals. – Sustainability may limit design options due to the need for sustainable materials or energy-efficient systems.
PRF 008	Disaster preparedness	Facilities include infrastructure for disaster preparedness, including evacuation routes, emergency supplies, and contingency plans.	Disaster preparedness ensures that the facility can handle unexpected events, ensuring the safety of occupants and the continuity of critical operations.	– Disaster preparedness may require significant planning and investment in emergency infrastructure. – Disaster preparedness may impact daily operations (e.g., having to maintain emergency drills or contingency testing). – Disaster preparedness infrastructure may require periodic updates based on new risks or regulations.

Item	Name	Statement	Rationale	Implications
PRF 009	Disaster recovery	Facilities maintain Disaster Recovery Plans (DRPs) to restore the IT systems, data, and operations they host in the event of a disaster.	A facility without a defined recovery plan leaves the restoration of what it houses to improvisation at the moment a disaster occurs, when decisions are hardest to make well and time is most costly to lose. Maintaining a Disaster Recovery Plan (DRP) in advance ensures that the IT systems, data, and operations a facility supports can be restored quickly and in a defined order, minimising the downtime and data loss the organisation would otherwise experience while a response is worked out from scratch.	– Disaster recovery may require investment in backup systems, offsite storage, and recovery planning. – Disaster recovery may increase complexity in managing data and IT systems across multiple locations. – Periodic testing of recovery plans may be necessary to ensure effectiveness.
PRF 010	Technology flexibility	Facilities are designed with the flexibility to incorporate new technologies as business needs evolve.	Technological flexibility allows the facility to adapt to advances in IT infrastructure, reducing the need for costly and disruptive redesigns.	– Technology flexibility might require additional investment in modular designs and adaptable systems. – Technology flexibility could delay implementation as future-proofing requirements could complicate immediate needs. – Regular technology reviews may be needed to ensure infrastructure remains up-to-date.
PRF 011	Integration with IT systems	Facilities support seamless integration with IT systems and infrastructure, ensuring that hardware, software, and physical environments work cohesively.	Integration with IT systems supports efficient operations, reduces the need for manual intervention, and streamlines workflows.	– Integration could lead to additional costs in ensuring compatibility between physical and IT infrastructure. – Integration may require continuous alignment between facility design and evolving IT system needs. – Integration may require a dedicated team to manage facility and IT integration efforts.
PRF 012	Space optimisation	Facility designs optimise space utilisation to maximise efficiency and minimise wasted areas.	A facility with unused or poorly allocated space carries the same operational cost as one that is fully utilised, without delivering the same value in return. Optimising space ensures that the cost of maintaining a facility is matched by the functionality and productivity it actually delivers from the resources available within it.	– Space optimisation may require detailed planning and continuous assessments to ensure space is used effectively. – Space optimisation may limit design options for flexibility due to spatial constraints. – Space optimisation may increase operational costs if space is not continuously reassessed.

Item	Name	Statement	Rationale	Implications
PRF 013	Energy efficiency	Facilities prioritise energy efficiency through the use of optimised building systems and sustainable practices.	A facility that consumes more energy than its operations require increases costs indefinitely and works against the organisation environmental commitments, regardless of how well the facility performs in other respects. Prioritising energy efficiency keeps operational costs proportionate to actual need and supports the organisation ability to sustain its operations over the long term without excessive resource consumption.	– Energy efficiency may require upfront investment in energy efficient equipment and technologies. – Energy efficiency may limit some design options in favour of sustainability. – Energy efficiency may require regular monitoring and adjustment to sustain performance over time.
PRF 014	Cost efficiency	Facilities minimise long-term operational and capital costs while maintaining performance and functionality.	Cost-efficient design ensures the facility delivers value over its lifetime, supporting business objectives without overextending budgets.	– Cost efficiency may involve compromises in design quality or feature sets to control costs. – Cost efficiency may require careful balancing of initial investments against long-term savings. – Cost efficiency may limit flexibility in selecting high-end materials or technologies.
PRF 015	Health and safety	Facilities adhere to health and safety to protect the well-being of all occupants and comply with legal requirements.	Ensuring health and safety in the workplace reduces the risk of accidents, supports compliance, and creates a safer environment for employees and visitors.	– Health and safety requirements may restrict certain design options or increase compliance costs. – Ongoing training and risk assessments may be required to maintain health and safety requirements. – Health and safety could require periodic facility inspections to ensure continued adherence to safety regulations.
PRF 016	Comfort and wellbeing	Facilities provide the comfort and wellbeing of employees and visitors, including considerations for lighting, temperature, and air quality.	A comfortable work environment improves productivity, reduces absenteeism, and enhances employee satisfaction.	– Comfort and wellbeing may increase initial setup costs due to investments in Heating, Ventilation, and Air Conditioning (HVAC) systems and lighting. – Comfort and wellbeing may require ongoing maintenance to ensure comfort standards are met. – Comfort and wellbeing may limit design choices if comfort requirements conflict with other priorities.

Table 7. SEF® Lean Version: Architectural Principles – Structural Profile – Facility Domain

2.3.8 INTERFACE PROFILE

The interface profile includes twenty-four architectural principles, which are presented in table 8.

Item	Name	Statement	Rationale	Implications
PRI 001	Interface ownership	Each interface has a clearly defined owner accountable for its design, documentation, trustworthiness, and lifecycle, from creation through to secure decommissioning.	Interfaces connect entities across business services, business processes, information, IT systems, and facilities, and often cross between domains of trust that would otherwise remain separate. An interface with no defined owner cannot be relied upon to remain trustworthy, properly documented, or aligned with what it connects, regardless of how well the entities on either side of it are managed independently. Assigning ownership ensures a single accountable party governs the interface throughout its lifecycle, maintains the trust levels of the domains it connects, and owns the risks and issues affecting it.	– Interface owners may need to approve changes to the interface, and its transition into operations, before either can proceed. – A Disaster Recovery Plan (DRP) may be required for each interface, approved and maintained by its owner, to ensure continuity if the interface is compromised. – Interface owners may retain accountability for risks and issues affecting the interface even where responsibilities, such as monitoring or suspension in response to a cyberattack are delegated to others.
PRI 002	Business service support	Business services are consumed through well-defined interfaces, whether the services are provided internally by other business functions or externally by third-party providers, and whether the consumers of those services are internal business functions or external parties	Standardised interfaces for business service consumption create a clear boundary between service producers and consumers, whether internal or external to the organisation, enabling consistent and controlled access to business services. This approach ensures that business services can be modified, upgraded, or even replaced without disrupting the consuming business functions or external parties, as long as the interface remains stable. It also provides a foundation for proper governance, monitoring, and management of service consumption across the organisation and with external consumers, leading to better service quality and risk management.	– Every business service may need a formally defined interface that specifies how it can be consumed, including required inputs, expected outputs, service levels, and channels, whether the consumer is internal or external. – Changes to business services may maintain backward compatibility with existing interfaces or include a clear migration path for service consumers, including external parties who may have less flexibility to adapt quickly. – Business service interfaces may include monitoring and measurement to track usage, performance, and compliance with service level agreements, for both internal and external consumption.

Item	Name	Statement	Rationale	Implications
PRI 003	Business collaboration	Business interfaces enable effective collaboration between business functions, teams, and stakeholders, whether internal to the organisation or external third parties.	Well-defined business interfaces (e.g., recurring meetings, stand-ups, and formal touchpoints) are essential for creating structured communication channels both within the organisation and with the external parties it depends on. These interfaces ensure consistent information flow, enable coordinated decision making, and prevent the formation of isolated practices that could hinder business effectiveness, regardless of whether the parties involved sit inside or outside the organisation. By standardising how business functions and external stakeholders interact, interfaces reduce communication overhead and create clear pathways for collaboration.	– Business functions may need to identify and document their key interaction points with other functions and with external parties, including required participants and meeting cadence. – Standard business processes, supported by application software, may be needed to support these interfaces (e.g., meeting templates, collaboration platforms, and documentation methods), some of which may need to accommodate external participants. – Regular review and measurement of interface effectiveness may be necessary to ensure business interfaces continue to serve their intended purpose and evolve with business needs, whether those needs originate internally or from external stakeholders.
PRI 004	Customer centric experience	Interfaces are designed, implemented, and maintained with a primary focus on delivering optimal customer experience and value, whether serving internal or external customers.	Customer centric interfaces are essential for business success as they directly impact satisfaction, adoption, and overall service effectiveness. When interfaces are designed with customer needs, preferences, and behaviours in mind, they lead to higher engagement, reduced friction, and improved service outcomes.	– Interface design may be driven by customer research, feedback, and usage patterns, requiring regular customer input and validation throughout the interface lifecycle. – Performance metrics for interfaces may include customer experience measures (e.g., satisfaction scores, ease of use, and adoption rates). – Interfaces may become adaptable to evolving customer needs and expectations, with built-in mechanisms for gathering feedback and implementing improvements based on customer insights.
PRI 005	Unambiguous interfaces	All interfaces are clearly defined with complete, unambiguous specifications that detail their aim, purpose, functionality, and usage parameters.	Clear and precise interface definitions are fundamental to successful service consumption and integration. When interfaces are explicitly defined with no ambiguities, the organisation reduces errors, minimises implementation time, and avoids costly misinterpretations. Clear definitions ensure that both producers and consumers have a shared understanding of how the interface works, what it delivers, and what it requires, thereby enabling reliable service delivery and consistent integration across the enterprise.	– Every interface may require comprehensive documentation that specifies inputs, outputs, preconditions, postconditions, error handling, and expected behaviours. – Interface definitions may undergo formal review and approval to ensure completeness and clarity before being released for use. – Changes to interface definitions may need to be explicitly versioned and communicated to all stakeholders, with clear documentation of what has changed and why.

Item	Name	Statement	Rationale	Implications
PRI 006	Breaking structural fragmentations	Interfaces overcome structural fragmentations by connecting isolated business functions and IT systems across the organisation.	Organisational structural fragmentations, also known as silos, create barriers that impede efficiency, innovation, and collaboration. Well-designed interfaces serve as bridges that connect these isolated fragments, enabling seamless information flow and business process integration. By deliberately breaking down these structural boundaries, interfaces create a more cohesive and agile organisation that can better respond to business needs, share resources effectively, and maintain operational consistency across different domains.	– Interfaces may need to be positioned strategically to connect isolated business functions and IT systems, with clear mapping of how they bridge organisational gaps. – Design of interfaces may prioritise cross-functional integration while maintaining appropriate security. – Regular assessment of organisational structure and technology landscape may be required to identify and address fragmentations through interface implementation.
PRI 007	Interoperability longevity	Data exchange interfaces support longevity by ensuring compatibility with future technology and evolving open standards.	Future-proofing exchange formats ensure that interfaces remain functional and relevant as technology advances, minimising the need for frequent redesigns. By using future-proofing exchange formats, interfaces can support backward compatibility, allowing legacy software systems to coexist with newer technology. Longevity also fosters innovation by ensuring that new application software can integrate seamlessly, and protects organisational investments by reducing technical debt and the risks associated with obsolescence.	– Designing for longevity might increase initial development complexity and costs. – Longevity could necessitate the adoption of extensible formats that allow for backward and forward compatibility. – Ongoing reviews may be required to address emerging technology and open standards without disrupting operations.
PRI 008	Consistent structuring	Data exchange interfaces maintain consistent structuring of data to ensure reliability and accuracy across all software systems.	Consistent data structuring ensures that data maintain their integrity as they flow between software systems, reducing the likelihood of misinterpretation or corruption during exchanges. This consistency simplifies integration efforts by ensuring that all software systems adhere to the same conventions for organising and representing data, making it easier to implement and manage interfaces.	– Ensuring consistency might require investments in data mapping and transformation for diverse systems. – Inconsistent data could lead to integration challenges or operational inefficiencies during implementation. – Maintaining consistency over time may involve regular audits and alignment with evolving organisational needs.

Item	Name	Statement	Rationale	Implications
PRI 009	Standardised exchange formats	Interfaces use standardised exchange formats to ensure compatibility and interoperability across diverse applications.	Standardised data exchange formats (e.g., XML, JSON) provide a common language for software systems to communicate effectively, eliminating barriers caused by disparate technologies, vendors, or application software. They reduce the need for extensive data transformation or custom integration layers, which can be time-consuming and prone to errors. Standardisation also supports compliance with industry and regulatory requirements.	– Adopting standardised formats might require reengineering legacy software systems to comply with accepted practices. – Standardised exchange formats could limit flexibility in using proprietary or customised data formats for specific needs. – Maintaining adherence to standard exchange formats may necessitate ongoing monitoring and updates as formats evolve.
PRI 010	Design consistency	Interfaces follow consistent design patterns and conventions across to ensure predictable behaviour, simplified integration, and reduced complexity.	When interfaces follow uniform patterns, they reduce cognitive load for developers, accelerate integration efforts, and minimise implementation errors. This consistency creates a predictable development environment where teams can work more efficiently, reuse existing knowledge, and deliver reliable solutions more quickly. It also enables better maintainability and reduces the Total Cost of Ownership (TCO) by establishing common practices that all teams can follow. By maintaining uniformity in interface design, the organisation can also significantly reduce cognitive load on users while increasing their productivity and satisfaction.	– Ensuring design consistency across interfaces might require additional time during the initial development phase to establish and adhere to standardised design patterns and conventions. – Following consistent design patterns could limit the ability to customise individual interfaces, as they need to prioritise uniformity over flexibility. – All interface development may be validated against established design patterns before release, with any deviations requiring explicit justification and approval. – Regular audits of existing interfaces may be conducted to identify and address inconsistencies, ensuring ongoing alignment with user expectations. – Regular training and documentation updates may be needed to ensure teams understand and correctly implement the consistent design patterns across all interfaces.
PRI 011	Interface interoperability	Interfaces ensure seamless interoperability with other IT systems to enable effective communication and collaboration.	An interface that cannot interoperate with the IT systems on either side of it prevents the entities it connects from exchanging information effectively, regardless of how well each system performs independently. Ensuring interoperability allows IT systems to communicate and collaborate as intended, regardless of their underlying technologies, maximising the value of IT investments and enabling flexible business operations across the enterprise.	– Interfaces may need to adhere to industry-standard protocols, data formats, and communication patterns, with clear documentation being followed and any deviations that may exist. – Interface designs may include standard error handling, logging, and monitoring to ensure reliable operation across system boundaries. – Interfaces that are not interoperable with a connected IT system may isolate that system from the rest of the organisation, undermining collaboration rather than enabling it. – Regular testing and validation of interface interoperability may be conducted, particularly when changes are made to

Item	Name	Statement	Rationale	Implications
				connected software systems or when new integration points are added.
PRI 012	Open protocols	Network protocols are based on open standards rather than proprietary solutions, ensuring transparency, broad compatibility, and the ability for security controls to be openly reviewed and validated.	Open protocols are essential for building secure, reliable, and future proof interfaces, since they benefit from community scrutiny, which leads to better security through transparent review processes and faster identification of vulnerabilities. By avoiding proprietary protocols, the organisation can reduce vendor lock-in risks and enable broader interoperability across different platforms and systems.	– All network protocols used in interfaces may need to be based on widely accepted open standards (e.g., HTTP, SSH, TLS), with any exceptions requiring thorough justification and executive approval. – Security implementations may need to be transparent and based on proven, publicly reviewed protocols that can be independently verified and validated. – Regular security assessments and protocol updates may be performed to ensure alignment with current good practices and to address any newly discovered vulnerabilities in the open protocols being used.
PRI 013	Scalable interfaces	Interfaces scale efficiently over time, handling increasing workloads, growing data volumes, and expanding user bases without degradation in performance or functionality.	Scalable interfaces are essential for supporting business growth and maintaining service quality over time. When interfaces are designed with scalability in mind from the start, the organisation can accommodate growing demands without requiring significant redesign or causing service disruptions. Scalability ensures that interfaces can adapt to increasing loads, data volumes, and user populations over time, while maintaining performance and reliability.	– Interfaces may need to be designed with clear scalability requirements and tested against projected growth scenarios, including documentation of scaling limits and upgrade paths. – Interfaces may be designed with performance benchmarks and automated scaling mechanisms, such as load balancing, caching, and resource optimisation, to handle growth in workload while maintaining response time requirements. – Regular capacity planning and performance monitoring may be conducted to identify scaling needs before they become critical, with clear processes for implementing scaling solutions proactively.
PRI 014	Responsive interfaces	Interfaces are designed and implemented to be responsive and performant across varying real-time conditions, including network states, device types, and user contexts.	Responsive interfaces are critical for maintaining consistent service quality and user satisfaction. When interfaces are designed to adapt and perform efficiently under varying real-time conditions, they ensure business continuity and user productivity regardless of circumstances. This approach recognises that modern software systems operate in dynamic environments where network conditions and access patterns can change rapidly. By building responsiveness into interfaces from the ground up, the organisation can deliver reliable, high-quality services that maintain performance even under challenging conditions.	– Interfaces may include appropriate caching, throttling, and optimisation mechanisms to ensure efficient operation across different network conditions and device types. – Regular performance testing and monitoring may be implemented to verify responsiveness under different real-time scenarios, with clear escalation paths for addressing performance degradation. – Interfaces may need to detect and adapt to the specific context they are being accessed from (e.g., device type or connection quality), rather than assuming uniform conditions for all users.

Item	Name	Statement	Rationale	Implications
PRI 015	Exposed application interfaces	Application software functionality is exposed to other software systems through well-defined interfaces, structured as discrete, independently consumable functions, building on the modularity, reusability, and low coupling already established for application software.	Application functionality that can only be used from within the application itself cannot be consumed by other software systems, regardless of how modular, reusable, or loosely coupled that functionality is internally. Exposing functionality through well-defined interfaces allows it to be consumed independently by other software systems, extending the benefit of modularity, reusability, and low coupling beyond the application's own boundary.	– Exposing functionality through an interface may require additional time and resources for initial implementation, due to interface definition and documentation requirements. – Managing multiple independently exposed interfaces may introduce operational complexity, requiring robust monitoring, versioning, and orchestration. – Exposed interfaces may require governance distinct from the application software behind them, to ensure interface quality and compatibility are maintained independently of changes made to the underlying application. – Interfaces exposing application functionality, such as Application Programming Interfaces (APIs), may need to adhere to recognised standards and protocols, so that consuming software systems can integrate with them predictably.
PRI 016	Usable interfaces	Interfaces ensure optimal usability, making them intuitive, efficient, and accessible for their intended users while minimising cognitive load and user errors.	Usable interfaces are critical for achieving business efficiency and user satisfaction, and they ensure that users can accomplish their tasks efficiently and effectively, leading to higher adoption rates and better return on technology investments. When interfaces are designed with strong usability principles, they reduce user frustration, minimise training requirements, and increase productivity. By prioritising usability in interface design, the organisation can reduce support costs, minimise user errors, and enable users to focus on their core tasks rather than struggling with complex or confusing interfaces.	– All interfaces may undergo usability testing with actual users before deployment, with clear metrics for measuring ease of use, task completion rates, and user satisfaction. – Interface designs may follow established usability guidelines, including clear navigation, appropriate feedback, and error prevention mechanisms. – Regular usability assessments may be needed to identify and address pain points, ensuring continuous improvement based on user feedback and behaviour analysis.

Item	Name	Statement	Rationale	Implications
PRI 017	User centricity	All graphical user interfaces are designed, implemented, and evolved with a primary focus on end user needs, preferences, and behaviours to ensure optimal usability, accessibility, and user satisfaction.	User centric graphical user interface design directly impacts software system adoption, user productivity, and business value realisation. When interfaces are designed around user needs and behaviours rather than technical constraints, they reduce user frustration, minimise training requirements, and increase operational efficiency. This approach ensures that technical functions are presented in ways that make sense to users, leading to fewer errors, faster task completion, and improved user satisfaction. By prioritising the user experience in interface design, the organisation can achieve better returns on their technology investments through increased user adoption and productivity.	- Graphical user interface designs may be validated through user research, testing, and feedback before implementation, with regular post-implementation assessments to ensure continued effectiveness. - Interface designs may adhere to accessibility good practices and account for diverse user needs, including support for different devices, abilities, and working environments. - User interface metrics may be established and monitored, including usability scores, task completion rates, and user satisfaction measures, with business processes in place to act on this feedback for continuous improvement.
PRI 018	User interface accessibility	User interfaces are accessible to all users, including those with disabilities, by adhering to recognised accessibility standards and guidelines.	Accessible user interfaces ensure inclusivity, enabling all users to interact with applications effectively, regardless of physical or cognitive abilities. They also promote compliance with legal and regulatory requirements, enhance user experience, broaden the potential user base, and demonstrate commitment to diversity and social responsibility, positively impacting the reputation of the organisation.	- Designing accessible interfaces might require additional development and testing efforts to meet diverse user needs. - Accessibility requirements could necessitate regular updates to align with evolving good practices. - Accessibility considerations might require integrating assistive technologies (e.g., screen readers or voice recognition) into the interface design. - Ensuring accessibility could lead to increased training needs for development teams to implement and maintain inclusive design practices.
PRI 019	Efficient communication	Network interfaces maximise efficiency by minimising latency, optimising bandwidth, and supporting high-throughput communication.	Efficient network protocols enable faster data transmission, reduced congestion, and better utilisation of available bandwidth, ensuring that software systems perform optimally under varying loads. This is critical for real-time application software, where delays can affect operations and user experiences. An efficient network also supports scalability by handling increased traffic without requiring significant infrastructure upgrades, while optimised protocols reduce resource consumption, contributing to cost savings and sustainability objectives.	- Achieving network efficiency might require investment in optimising existing protocols or upgrading infrastructure, along with ongoing performance monitoring and tuning that demands specialised skills and dedicated resources. - Protocol efficiency could depend on periodic performance tuning and monitoring to adapt to evolving requirements. - Optimising for low latency may conflict with optimising for high throughput, requiring careful balancing based on application requirements.

Item	Name	Statement	Rationale	Implications
PRI 020	Resilient communication	Network interfaces implement resilient protocols to ensure uninterrupted communication and data exchange under varying conditions.	Resilient communication protocols provide mechanisms to handle network disruptions (e.g., error correction and failover), and ensure reliable delivery of data even in adverse conditions (e.g., packet loss, congestion, or hardware failures). Resilience is critical for maintaining continuity in distributed environments and for application software where data integrity and availability are paramount. It reduces the risk of communication breakdowns, enhances user confidence, and supports business continuity planning.	– Resilient protocols might introduce additional overhead, redundancy, and infrastructure complexity, potentially affecting performance in low latency scenarios and increasing resource consumption. – Ensuring resilience may require continuous monitoring and updates, including advanced diagnostic capabilities, to detect and recover from communication issues and address emerging threats. – Designing for resilience might require implementing diverse failover mechanisms, which can increase design and operational complexity.
PRI 021	Reliable communication	Network interfaces utilise protocols that ensure reliable communication through guaranteed data delivery and error handling mechanisms.	Reliable communication protocols ensure data are transmitted accurately and in the correct sequence, even over unreliable networks. They provide acknowledgments, retransmission of lost packets, and flow control to maintain data integrity and avoid congestion. This reliability is essential for software systems that require accurate and complete data exchanges fostering trust in system outputs and preventing operational disruptions.	– Reliable protocols might introduce latency due to acknowledgment and retransmission mechanisms. – Implementation may require balancing reliability with performance needs for time-sensitive software systems. – Dependence on reliable protocols could necessitate additional configuration and optimisation to suit specific use cases. – The use of reliable protocols might not be suitable for use cases that depend on audio and video.
PRI 022	Scalable interconnectivity	Datacentres are designed with scalable interconnection capabilities to accommodate growth in service provider connections and data traffic.	Scalable interconnectivity ensures that the datacentre can expand its capacity for new connections without major infrastructure overhauls. It allows the datacentre to keep pace with evolving business needs and increasing traffic demands from both internal and external sources.	– The design or selection of datacentres requires careful planning to ensure infrastructure interconnectivity is designed with future growth in mind. – The design or selection of datacentres could involve or require additional upfront investment in flexible, modular networking equipment. – Ongoing assessments of interconnection needs may be required to ensure scalability remains aligned with business expansion.

Item	Name	Statement	Rationale	Implications
PRI 023	High availability connections	Datacentres include high-availability network connections to ensure uninterrupted service and minimal downtime.	High availability connections are crucial for ensuring continuous data flow and service uptime. Redundant links, failover capabilities, and load balancing minimise the risk of single points of failure, supporting business continuity and resilience.	– High availability connections may require investment in redundant infrastructure, which could increase operational costs. – Additional management and monitoring tools may be needed to ensure seamless failover during outages. – High availability connections might require periodic testing and validation to ensure that failover mechanisms function as expected.
PRI 024	Multi provider connectivity	Datacentres support connections to multiple service providers to ensure flexibility and reliability in service delivery.	Connecting to multiple service providers increases redundancy, flexibility, and resilience, allowing the datacentre to quickly adapt to changes in service providers or demand. It reduces the risk of vendor lock-in and ensures continuous service even in the event of provider issues.	– Multi provider connectivity may require additional physical space and infrastructure to manage multiple connections. – Multi provider connectivity could lead to increased complexity in managing and monitoring the connections. – Multi provider connectivity might incur additional costs for maintaining multiple provider contracts and interfaces.

Table 8. SEF® Lean Version: Architectural Principles – Interface Profile

2.3.9 SECURITY PROFILE

The security profile includes twenty-seven architectural principles⁵, which are presented in table 9.

Item	Name	Statement	Rationale	Implications
PRS 001	Security control ownership	Each security control has a clearly defined owner accountable for its effectiveness, coherence with the wider layered defence, and lifecycle throughout its existence.	Security controls are only as effective as the accountability behind them, and a control with no defined owner cannot be relied upon to remain proportionate, coherent with other controls it operates alongside, or capable of mitigating the risks it was designed to address. Assigning ownership ensures a single accountable party manages the control from design or acquisition through to retirement, keeps it aligned with business objectives and regulatory requirements, and owns the risks and issues affecting its effectiveness.	– Security control owners may need to approve the authorised scope, configuration, and changes made to their control before these can proceed. – Gaps between the intended and actual effectiveness of a control may need to be identified, tracked, and remediated as security debt, rather than left unaddressed. – Security control owners may retain accountability for risks and issues affecting their control even where responsibilities such as monitoring or tuning are delegated to others.
PRS 002	Unique identity	Every human and non-human entity has a unique, verifiable digital identity established and maintained by standardised and consistent business processes throughout its lifecycle.	Unique identities enable accountability by attributing actions to specific human and non-human entities, including devices, IT systems, and software system processes. Without them, the organisation cannot reliably determine who or what is accessing resources, making it impossible to enforce appropriate access controls, detect unauthorised activity, or satisfy audit and compliance requirements. Consistent identity management across IT systems, software system processes, and physical facilities prevents fragmentation, reduces administrative overhead, and ensures that identity changes (e.g., role transitions or terminations) are automatically reflected across all digital and physical resources.	– Identity lifecycle business processes may not be standardised or consistently applied across the organisation. – Non-human entities (e.g., devices, IT systems, software system processes) may be overlooked or inadequately identified. – Identity attributes may be incomplete, inconsistent, or poorly maintained over time. – Duplicate or ambiguous identities may exist, undermining uniqueness and verification.

⁵ Some architectural principles of the security profile were derived from Saltzer and Schroeder (1975) and OWASP (2010).

Item	Name	Statement	Rationale	Implications
PRS 003	Verified identity	Access to any organisational resource, including devices, IT systems, data, and physical facilities, is granted only after the identity of the entity has been securely verified in accordance with identified and assessed security risks.	Verified identity ensures that only legitimate entities, human or non-human, can request access to organisational resources. By requiring identity verification appropriate to the sensitivity of the resource and the prevailing threat context (e.g., through multi-factor or context-aware mechanisms), the organisation prevents impersonation, credential theft, and misuse. Without robust identity verification, authorisation controls lose integrity, since any threat actor could masquerade as a trusted user, IT system, or software system process, undermining accountability, security, and compliance.	– The required strength of identity verification may not align with assessed security risks. – Verification mechanisms (also known as authentication mechanisms) may be bypassed, compromised, or inadequately protected. – Identity verification may not be consistently enforced across all resources and access points. – Non-human entity identities may be difficult to verify or may lack appropriate verification methods.
PRS 004	Controlled access	Every human and non-human entity is assigned explicit permissions to access selected authorised resources and perform predefined actions on them.	Controlled access prevents unauthorised or excessive access to organisational resources and ensures that human and non-human entities can perform only those actions necessary for their roles or functions. Explicit authorisation replaces default or inherited permissions, ensuring that access rights are documented rather than assumed. This approach reduces security risks, enhances auditability, and minimises exposure to insider threats, errors, and misuse, while supporting compliance.	– Access rights may default to inherited or implicit permissions rather than explicit assignment. – Business roles and their assigned tasks may not be clearly defined, preventing accurate authorisation. – Access rights may not be documented, making audit and review difficult or impossible. – Ongoing review and adjustment of access rights may be neglected or overlooked.
PRS 005	Never trust always verify	Assets are grouped according to their function and value, and are accessed only by subjects whose identity and context are verified and deemed trustworthy at the time of access.	The protection of assets can no longer rely solely on perimeter-based isolation and implicit trust in all subjects inside that perimeter. Grouping assets together under a domain of trust, and granting access to this domain only to subjects whose identity and context are continuously verified, reduces the likelihood of threats originating from inside the perimeter and those associated with lateral movement.	– Grouping assets needs inputs from service owners, business process owners, and asset owners. – Assigning trust levels to domains of trust may become challenging if valuation of assets is absent. – Zero trust may be limited to the infrastructure domain leaving open doors in the business, information, application, and facility domains. – The existing Identity and Access Management (IAM) function may not be able to support the zero-trust model. – Micro-segmentation or compartmentalisation may be difficult to implement.

Item	Name	Statement	Rationale	Implications
PRS 006	Situational awareness	All assets owned by the organisation, and assets owned by third parties, where the organisation is accountable or responsible for them, are identified and mapped. This mapping captures ownership, purpose, value, location, interoperation, and collaboration.	In order to protect assets effectively, it is necessary to know what they are, who owns them, where they are located, how they interoperate with other assets, with whom they collaborate, and who threatens their confidentiality, integrity, and availability. Without this visibility, security risks cannot be assessed accurately and security controls cannot be applied consistently.	– The identification of assets without owners could become difficult. – The identification and mapping of assets in the supply chain may not be obvious. – The identification and mapping of assets without a clear understanding of the current state may be misleading. – The identification and mapping of assets may ignore interim and target states. – The identification and mapping of assets is often limited to information assets.
PRS 007	Need to know	Information access is restricted to authorised individuals with demonstrated business need, scoped to specific assets, and limited to the time period necessary to accomplish defined business objectives.	Sharing the correct knowledge between the right parties encourages collaboration and teamwork, and achieves better results faster. When this knowledge is available to everyone for an unlimited period of time, its exposure to unauthorised access may undermine the mission of the organisation or may cause or foster a breach of contractual, regulatory, or legal requirements.	– The difference between subjects and objects may not be understood clearly. – Defining legitimate business need for information access may be subjective, leading to inconsistent application of need to know. – Revoking access when the defined time period expires or the business outcome is achieved requires active monitoring, which may be inadequately resourced or overlooked. – Need to know may exclude non-human subjects.
PRS 008	Least privilege	An authorised subject is assigned the minimum set of privileges that is necessary to perform the tasks that are derived from the corresponding role.	Authorised subjects (i.e., users, IT systems) need the right permissions to perform the expected actions on objects (i.e., IT systems, data). Providing these subjects with more permissions than required, could lead to misuse. Likewise, providing these subjects with fewer permissions than required could lead to denial-of-service conditions.	– The difference between subjects and objects may not be understood clearly. – Permissions are derived from roles. If these roles are not well defined, the right level of permissions cannot be assigned. – Maintaining the right set of permissions may be overlooked. – Least privilege may exclude non-human subjects.
PRS 009	Need to use	An authorised subject is provided with elevated privileges on a specified asset only for the time that is needed to perform the assigned tasks on that asset.	Granting administrators with unlimited access to privileged accounts is unnecessary and increases the likelihood of privileged accounts to be misused or compromised.	– Elevating privileges on a Just in Time (JIT) basis can be difficult without a Privileged Access Management (PAM) system. – The administration of elevating privileges on a JIT basis without a documented, verified, and validated business processes may cause denial of service conditions. – Elevating privileges on a JIT basis may be challenging for 3rd party access if these administrators are not on boarded formally by the Identity and Access Management (IAM) business function.

Item	Name	Statement	Rationale	Implications
PRS 010	Need to audit	All actions of subjects, authorised and unauthorised, on objects are audited.	When preventive security controls fail to stop the manifestation of threats, detective security controls should detect them to trigger the corresponding corrective security controls. Detecting the manifestation of threats depends on auditing accounting items (i.e., event and contextual data) generated by IT systems and security controls.	– Auditing can be undermined if segregation of duties is not applied. – Auditing may not be perceived as an independent function. – The Security Operations Centre (SOC) may not be considered an auditing function. – Auditing may become inefficient and ineffective if performed in silos. – Auditing may undermine the privacy of individuals.
PRS 011	Segregation of duties	Any critical activity that could cause or foster conflict of interest, fraud, or error is separated between at least two parties with different responsibilities.	Conflicts of interest, fraudulent actions, and errors arising from certain critical activities involving request and approval, or accounting and auditing, or Chinese Walls can be prevented by separating them between at least two parties with different responsibilities.	– Identifying activities that could be subject to conflict of interest, fraud, or error can be challenging without documented business processes. – Role Based Access Control (RBAC) may not support certain requirements for segregating duties. – Segregating duties using administrative security controls only may not be effective.
PRS 012	Secure by design	Security controls proportionate to identified security risks are embedded in systems during their design, rather than retrofitted after implementation.	Systems designed without considering security are likely to contain vulnerabilities or malware that are costly and disruptive to detect and remediate after implementation. Embedding security during the design phase ensures that security becomes an inherent property of the system rather than an addition to it.	– Commercial-of-the-Shelf (COTS) systems may not be secure by design. – Vendors may claim that their products are secure by design but these products may be subject to vulnerabilities. – Secure by design may apply to applications only and not to integrated IT systems. – Secure by design may not apply to business processes as the term system is associated with technology only.
PRS 013	Privacy by design	Systems are designed and implemented to minimise the collection, use, retention, and disclosure of Personally Identifiable Information (PII) from the outset rather than added retrospectively.	Personally Identifiable Information (PII) is subject to regulatory and legal obligations that require it to be collected, used, retained, and disclosed only to the extent necessary and with appropriate protections in place. Systems designed without considering privacy are likely to collect more PII than necessary, retain it longer than required, and expose it to unnecessary risks, all of which may result in harm to individuals and regulatory fines for the organisation. Embedding privacy during the design phase ensures that data minimisation and protection become inherent properties of the system, and that compliance is achieved systematically rather than through costly and less effective retrospective measures.	– Privacy by design may be confused with secure by design. – Privacy by design may not apply to business processes as the term system is associated with technology only. – Privacy by design may apply to applications only and not to integrated IT systems. – Commercial-of-the-Shelf (COTS) systems may not support privacy by design.

Item	Name	Statement	Rationale	Implications
PRS 014	Secure by default	Systems are configured to include the minimal possible set of components and functions needed to produce the expected behaviour, and are delivered in their most secure configuration, requiring explicit and justified action to reduce security settings.	When a system contains more components and functions than required to produce the expected behaviour, its footprint increases, leading to unnecessary entry and exit points and increased complexity. The more complex a system is, the more defects it might have. The more defects a system has, the more vulnerabilities it may contain. Furthermore, the larger the system footprint, the greater the attack surface. Similarly, systems that are not delivered in their most secure configuration are likely to be deployed with insecure settings that are overlooked or never remediated, providing unnecessary opportunities for exploitation.	– Secure by default may not include business processes. – Secure by default may be limited to operating systems only. – Secure by default may be confused with secure configuration.
PRS 015	Privacy by default	Systems are tailored and configured by default to minimise data collection, restrict access, apply minimal retention periods, require opt-in consent, and prohibit third-party data sharing, while reducing these protections requires explicit action.	When Personally Identifiable Information (PII) is exposed unnecessarily (e.g., use PII for testing systems), or when more PII is disclosed unnecessarily to support a service, then the privacy of individuals could be undermined (e.g., disclosing the date of birth when only the age is needed). Likewise, any PII provided by an individual to enable the optimal use of a service should only be kept for the amount of time necessary to support this service.	– Privacy by default may be confused with secure by default. – Privacy by default may not include business processes. – Privacy by default may exclude security monitoring.
PRS 016	Controlled change	All changes to the architectural model (e.g., business services, business processes, information and data, application software, hosting infrastructure, physical facilities, interfaces, and security controls) are reviewed, assessed, and authorised before design, testing, and implementation.	Controlled change ensures that modifications to the architectural model are made deliberately and safely, minimising the risk of service disruption, security breaches, or operational failures. By requiring formal approval, testing, and documentation, organisations maintain system stability, preserve security controls, and ensure that changes can be tracked, audited, and reversed if necessary.	– Change management business processes may not be consistently applied across all business processes, IT systems, and environments. – Urgent or emergency changes may bypass formal controls, introducing risk or creating undocumented modifications. – Testing environments may be inadequate or unavailable, preventing proper validation before production deployment. – Documentation and approval requirements may be viewed as bureaucratic obstacles, leading to informal or unauthorised changes.

Item	Name	Statement	Rationale	Implications
PRS 017	Defence in depth	All assets owned by the organisation or assets owned by third parties, where the organisation is accountable or responsible for them, are protected by a centrally managed defence in depth comprising lines of defence, tiers of defence, and layers of defence.	Implementing a certain category of security controls (e.g., preventive controls) in a monolithic domain of trust (e.g., with no segmentation) in a selected domain of the architectural model (e.g., infrastructure domain) does not provide any defence in depth, as it leaves gaps in the layers of defence (i.e., absence of deterrent, detective, and corrective security controls) and gaps in the tiers of defence (i.e., absence of security controls in the remaining domains of the architectural model). As a result, one small compromise can lead to a holistic compromise (i.e., due to the absence of segmentation).	– Defence in depth is often implemented by deploying security solutions at random. – Defence in depth may be implemented using a 'tick in a box' exercise. – Defence in depth may be limited to preventive security controls. – Defence in depth may be limited to security solutions operating in silos. – The management of defence in depth may be fragmented.
PRS 018	Open design	The selection of security solutions and their components requires their designs to be open to scrutiny.	Security through obscurity does not make cryptographic primitives stronger or make security solutions more resilient against the manifestation of threats.	– Issues of proprietary software and trade secrets complicate the application of open design. – In some cases, organisations do not want their designs be made public to protect them from competitors. – Open design may be implemented using unsupported open-source systems. – Open design may be confused with publishing the whole model of the organisation.
PRS 019	Diversity of defence	Security controls are not subject to a single point of failure.	When security controls share common foundations, the compromise of this foundation can lead to the neutralisation of all these controls. For example, the access control capabilities of different firewalls that share the same operating system can be evaded by exploiting a vulnerability of their operating systems. When the same operating system under the same physical or virtual appliance offers more security controls (e.g., firewall, NIDS or NIPS, antimalware), the impact of this exploit may jeopardise whole sections of the defence in depth capability.	– Diversity of defence may need a diverse set of skills to manage and maintain the corresponding security controls. – Diversity of defence may not be feasible in certain cases (e.g. two different endpoint security controls may not be able to coexist). – Security controls may not support open standards to support seamless interoperation or integration.
PRS 020	Enterprise coverage	Security controls mitigate risks holistically instead of shifting risks somewhere else or creating new ones.	Deploying security controls in isolation may mitigate the security risks within the scope of the coverage but simultaneously this practice may shift the same risks somewhere else or create new risks within the same scope or somewhere else. Deploying security controls to cover the enterprise level considers and addresses existing and new risks.	– Enterprise coverage may not be achieved unless the organisation is documented as an architectural model. – If not published carefully, enterprise coverage may send the wrong message to stakeholders who may think that the cost of security could increase unnecessarily.

Item	Name	Statement	Rationale	Implications
PRS 021	Fail securely	System failure causes no harm or minimal harm to the system and the data contained therein.	Failure is unavoidable and systems can fail due to defects in their development or configuration. Adversaries may try to make systems crash to reveal potential exploitable vulnerabilities.	– Fail securely may not be achieved in Commercial-of-the-Shelf (COTS) systems. – Applying ‘Deny All’ when access control systems fail may cause denial of service conditions.
PRS 022	Simplicity of security	Security controls are deployed only if they are needed to deter threat agents, prevent and detect the manifestation of threats, and correct the consequences of such manifestations.	Unnecessary security controls increase system complexity and attack surface. Security controls themselves can introduce weaknesses in the systems they are meant to protect and may create a false sense of security if deployed without clear justification. Minimising controls to only those essential for addressing specific threats reduces both system complexity and potential vulnerabilities.	– Simplicity of security may oversimplify security, leaving unprotected systems exposed to compromise. – Simplicity of security may be confused with security usability.
PRS 023	Usability of security	Security solutions are designed for ease of use and management, minimising the potential for user error or misconfiguration.	Security solutions are only effective when used and managed correctly. When security solutions require complex user interactions or decision making, or when they are difficult to manage, wrong decisions or configurations may weaken the defence in depth.	– Usability of security may be limited to isolated security solutions, requiring many management consoles. – Usability of security may increase integration efforts.
PRS 024	Proportionality of security	The selection of security controls is proportionate to the security risks that need to be mitigated.	Selecting security controls without considering the security risks that need to be mitigated may create a false sense of security affecting the exposure of assets, or it may cause or foster denial of service conditions affecting productivity.	– Proportionate security controls may be confused with low-cost security products. – Proportionate security controls may be misunderstood and affect the diversity of defence.
PRS 025	Enterprise resilience	The organisation has the ability to anticipate, prepare, detect, respond, and adapt to adverse business disruptions.	When preventive security controls fail, detective security controls identify threat manifestation and trigger corrective security controls to contain the threat, eradicate it from compromised systems, and restore systems to their normal operational state.	– Enterprise resilience may be confused with IT incident management. – Enterprise resilience may require business continuity to include the cyber world. – Enterprise resilience may be limited to cyber resilience.
PRS 026	Supply chain transparency	The supply chain of the organisation is transparent; suppliers and customers are grouped in tiers and are assigned a level of trustworthiness.	Obfuscated supply chains may be utilised to introduce malware and backdoors in systems or in components, or may be used to compromise systems or to introduce malicious implants as part of the maintenance process. Contract compliance, assurance in upstream and downstream, and audits offer a better level of transparency, responsibility, and accountability.	– Assigning a level of trustworthiness to a supplier or customer at a specific point in time may be perceived as a constant attribute. – The scope of the supply chain may be limited to suppliers of IT services or IT products.

Item	Name	Statement	Rationale	Implications
PRS 027	Secure public cloud	The use of public cloud offerings is subject to industry security assessments.	The use of public cloud offerings moves the control of systems and data from the organisation to Cloud Service Providers (CSPs). Although assuring the services offered by Cloud Service Providers (CSPs) is challenging, a set of assessments can be performed using the guidelines contained in the Cloud Security Principles of the National Cyber Security Centre (NCSC), using cloud specific ISO/IEC certifications, and using the guidelines, codes of conduct, control matrix, and certifications of the Cloud Security Alliance (CSA).	– The Cloud Security Principles, issued by the NCSC, are high level and might not be straightforward to tailor them to specific cloud offerings. – The Cloud Security Alliance (CSA) Security, Trust, Assurance, and Risk (STAR) Registry might confuse business stakeholders as the Cloud Security Alliance (CSA) Open Certification Framework covers three levels. – Most CSPs comply with Cloud Security Alliance (CSA) Security, Trust, Assurance, and Risk (STAR) Registry Level 1 Self-Assessment, which might be considered mistakenly as the golden standard. – Cloud Service Providers (CSPs) could claim compliance with ISO/IEC 27001:2013 but may not comply with cloud specific standards (e.g., ISO/IEC 27017:2015 and ISO/IEC 27018:2025).

Table 9. SEF® Lean Version: Architectural Principles – Security Profile

3 BENEFITS

Establishing well-formed architectural principles generates substantial benefits that span governance, coherence, decision making, risk management, and cost efficiency. The following business benefits are provided:

- A. **Foundation for Effective Governance.** Principles provide the norms from which policies can be derived and standards specified, giving the wider governance chain something substantive to enforce. Enforceability improves because policies traceable to a clearly stated principle carry a rationale, rather than existing as arbitrary rules. Governance effort is better targeted because attention concentrates on the principles that matter most, instead of being spread across long, undifferentiated lists with no enforcement mechanism behind them.
- B. **Architectural Coherence.** A well-formed set of principles allows architectural decisions, along with their supporting management practices, to be evaluated against the same underlying norms, regardless of which team or domain is making the decision. Cross-domain conflicts are reduced because choices in one area are less likely to silently undermine decisions made in another. Long-term coherence is sustained because principles, being durable by design, continue to hold the architectural landscape together, free of silos.
- C. **Strategic Alignment.** When principles are clearly established, architectural decisions are anchored to a consistent expression of organisational intent rather than to individual preference. Explicit principles allow strategic goals to be traced through to specific architectural choices, closing the gap between what the organisation says it wants and what actually gets built. Strategic drift is reduced because deviations from stated intent become visible and can be challenged against a defined norm, rather than passing unnoticed.
- D. **Consistent Decision Making.** Architects and engineers gain a shared reference point against which design compromises can be evaluated, reducing reliance on individual judgement or precedent alone. Faster decisions are enabled because recurring compromises no longer need to be debated afresh each time they arise. Consistency across stakeholders improves because independent decisions, made by different people at different times, converge on the same underlying norms rather than diverging silently.
- E. **Reduced Architectural Risk.** Evaluating a requirement against a principle reveals conflicts that would otherwise only surface once that requirement had already been built out. For example, the 'need to know' principle would flag a requirement calling for information to be shared freely, exposing the conflict before it is built into the design. Costly rework is avoided because designs are evaluated against durable norms at the point of decision, rather than being corrected retrospectively once a conflict has already been built into the system.

- F. **Improved Cost Efficiency.** Return on Investment (ROI) improves because principle led decisions reduce rework, redundant investment, and conflicting choices that would otherwise erode the value of organisational spend. Total Cost of Ownership (TCO) decreases because durable principles discourage short-term decisions that carry hidden long-term maintenance, transition, or replacement costs. Budgeting becomes more predictable because principle aligned decisions are less likely to require costly correction once strategic, operational, or regulatory context shifts.

GLOSSARY

Glossary	
Term	Description
AI	Artificial Intelligence
API	Application Programming Interface
BCP	Business Continuity Plan
CC	Creative Commons
CDN	Content Delivery Network
COTS	Commercial of the Shelf
CSA	Cloud Security Alliance
CSP	Cloud Service Provider
DNS	Domain Name System
DRP	Disaster Recovery Plan
FSM	Finite State Machine
HVAC	Heating, Ventilation, and Air Conditioning
IaaS	Infrastructure as a Service
IaC	Infrastructure as Code
IAM	Identity and Access Management
IoT	Internet of Things
JIT	Just in Time
KPI	Key Performance Indicator
MDM	Master Data Management
NCSC	National Cyber Security Centre
PaaS	Platform as a Service
PAM	Privileged Access Management
RBAC	Role Based Access Control
ROI	Return on Investment
RPO	Recovery Point Objective
RTO	Recovery Time Objective
SaaS	Software as a Service
SEF	Secure Enterprise Framework
SLA	Service Level Agreement
SOC	Security Operations Centre
SoD	Segregation of Duties
STAR	Security, Trust, Assurance, and Risk
SSOT	Single Source of Truth
SVOT	Single Version of Truth
TCO	Total Cost of Ownership
VLAN	Virtual Local Area Network

REFERENCES

- BARUTTIS, A. (2020). *SEF® Lean Version* [PDF]. Release 4.0. Technognomi Ltd. Available at: <https://github.com/abaruttis/secure-enterprise-framework-lean>.
- DIETRICH, A.E. (1995). How to Align Corporate Goals and Information Technology. *Communications News*, 32(10), p. 24.
- KING, W.R. (1978). Strategic Planning for Management Information Systems. *MIS Quarterly* (2:1), pp. 27-37. Available at: <https://www.jstor.org/stable/249104>.
- KOTUSEV, S. (2016). *The History of Enterprise Architecture: An Evidence-Based Review*. [PDF]. *Journal of Enterprise Architecture*, 12(1), pp. 29–43. Available at: <https://www.researchgate.net/publication/308936998>.
- OWASP FOUNDATION (2010). *OWASP Secure Coding Practices – Quick Reference Guide* [PDF]. Available at: https://owasp.org/www-project-secure-coding-practices-quick-reference-guide/assets/docs/OWASP_SCP_Quick_Reference_Guide_v21.pdf.
- RICHARDSON, G.L., JACKSON, B.M., DICKSON, G.W. (1990). *A Principles-Based Enterprise Architecture: Lessons from Texaco and Star Enterprise* [PDF]. *MIS Quarterly* (14:4), pp.385-403. Available at: <https://doi.org/10.2307/249787>.
- RIVERA, R. (2007). *Am I Doing Architecture or Design Work?* [PDF]. *IT Professional*, 9(6), pp. 46-48. Available at: <https://doi.org/10.1109/MITP.2007.107>.
- RIVERA, R. (2013). *The PRISM Architecture Framework – Was It the Very First Enterprise Architecture Framework?* [PDF]. *Journal of Enterprise Architecture*, 9(4), pp. 14-18. Available at: <https://www.researchgate.net/publication/336854686>.
- SALTZER, J.H. and SCHROEDER, M.D. (1975). *The Protection of Information in Computer Systems* [ONLINE]. *Proceedings of the IEEE*, 63(9), pp. 1278–1308. Available at: <http://web.mit.edu/Saltzer/www/publications/protection/>.